

# The Verifier Never Showed Up

Thirty years of digital identity programs, sorted by how they actually failed, and why the half of the system that decides adoption is the half nobody funds.

---

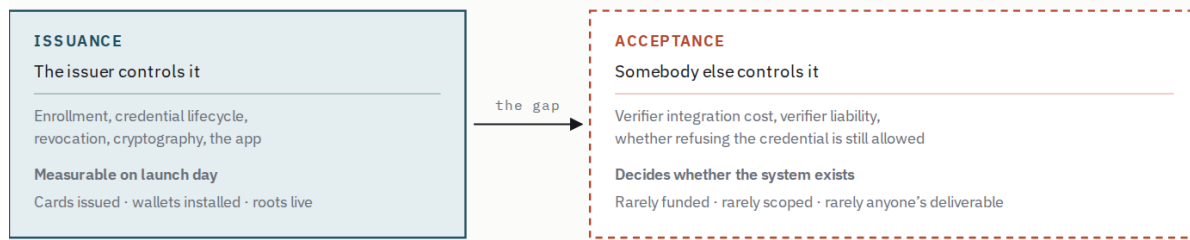
RYAN HURST · SEPTEMBER 2025, REVISED AUGUST 2026

*This began as a talk. In October 2025 I stood up at the State-Endorsed Digital Identity Summit at Utah Valley University and opened with a photograph of an Old Babylonian field-sale tablet impressed with a cylinder seal, to make the point that the question is old even where the technology is not. The same tablet opens section 1 below. I also told that room that seven in ten digital identity programs fail. Building the record put it at better than half, and the reason I had the wrong number is that failures get written up and quiet abandonments do not.*

*Written up through August 2026. Figures, program statuses and regulatory timelines describe the position as of that date, and several systems discussed carry future effective dates. Treat it as a snapshot of a record and where it was heading, not a current-state reference.*

## Contents

## ONE SYSTEM, TWO HALVES, ONE BUDGET



Almost every program in the record built the left box well and assumed the right box would follow.  
The exceptions did not solve the right box either. They found somebody who already had a reason to verify.

An identity program is scored on the half it controls. Adoption is decided by the half it does not. That asymmetry is not a management failure. It is what happens when the deliverable and the outcome belong to different parties, and it explains more of the record than any argument about cryptography, architecture or privacy design.

Of the twenty-eight programs in section 11 where I could identify an outcome, nineteen worked. I would not read much into that. I could only tag programs somebody had written about. Pilots that died quietly left nothing to tag.

What is less arguable is the shape of the failures. Read thirty years of post-mortems and the striking thing is not that they are numerous. It is that the cryptography was almost always fine. Germany built a technically sound card, put the function on ninety-seven per cent of cards by administrative decree, and got twenty-two per cent usage. The United Kingdom spent £233.3 million on a certified federation of commercial identity providers and shut it down. Microsoft designed InfoCard around principles that were, and remain, architecturally correct, and it died of developer friction. The European Union created legal status for electronic signatures in 1999 without creating the interoperability that would make them useful, then spent two decades discovering that legal status and utility are different things.

The conventional reading is that identity is a governance problem rather than a technology problem. That is true and too vague to act on. Governance is a category, not a diagnosis, and a category cannot tell an architect which of two designs to build or a minister which of two programs to fund.

This post proposes something narrower. There is a specific structural asymmetry that generates most of the record, and it is in the diagram above. An identity system has an issuance half and an acceptance half. The issuer controls, funds, staffs and is measured on the first. The second is where adoption is decided, and it sits with verifiers (banks, agencies, airlines, employers, merchants) whom the issuer usually cannot compel and rarely compensates. Programs optimize the half they own. The half that decides gets a paragraph in the business case.

Follow that asymmetry and several things fall out. It explains why anchor tenants predict outcomes better than any technical variable, being verifiers who arrived with an independent reason to verify. It explains why regulatory liability determines

architecture rather than merely constraining it. And it explains slow failure, because the same asymmetry runs forward in time. Launch is scored, operation is not.

*Identity systems are not usually built badly. They are usually built entirely, on the side of the transaction that does not decide the outcome.*

---

#### THE ARGUMENT IN FIVE CLAIMS

1. Acceptance decides, and it is nobody's job. An issuer can plan, fund and report on issuance. Acceptance belongs to verifiers with their own budgets, regulators and backlogs, so the half that determines the outcome is never anybody's deliverable. A state can compel it, and that is not an exception to this claim but a payment plan: Germany bought a coverage number that means nothing, Japan bought real acceptance and found the operating model underneath had never been tested. The first demand nobody has to manufacture may be arriving now, from agents that cannot act for a person without it.

§12 · §20 · §21

2. The mathematics was never the problem. In this sample, I did not identify one program that failed because the cryptography was weak. The failures I could identify were failures of incentives, coordination and politics, which means improving the technical layer cannot rescue a structurally doomed program, and arguing about it is a way of working on the tractable half.

§10 · §11

3. Residual responsibility sets the value ceiling. In security engineering, to trust something is to be vulnerable to it, and regulators price that correctly even when vendors do not. A certified verification service can now perform the identity-verification component of a bank's customer due diligence, but the bank remains responsible for the adequacy of the overall determination, so the economic question is how much duplicated work the applicable rules and its own risk model let it stop doing. Above the floor a credential removes real work; near it, the residual responsibility caps what any credential can remove, and the use cases where holder-controlled designs promise most are the ones where that residue is largest.

§13 · §14

4. Launch is the start of the bill. Without a funded operating model, on the order of a tenth of build cost every year, a working system decays into one that runs without delivering. One lapsed supplier certificate kept a working national login off its trust-framework register for nine months. And the choices made in the first eighteen months, identifier, binding, revocation and algorithm agility, harden into decisions nobody can reach from inside.

§15 · §16 · §18

5. Change what gets counted, or nothing else changes. A program scored on credentials issued will optimize credentials issued. Scored on transactions completed at a verifier under no obligation to participate, it has to solve the deciding half, because nothing else moves the number. This is the one recommendation here that the record cannot verify, because no program in it ever made the switch.

§19 · §22

---

If you take one thing away, take two questions. Would some verifier still need to solve this problem if the program did not exist? And has anyone costed the years after

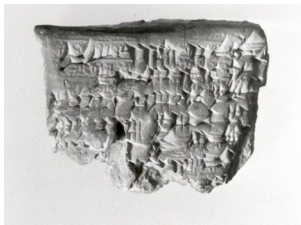
launch? Two questions against eleven failure modes is a shortcut rather than a substitute, and a proposal can pass both and still be dead on a liability rule it cannot reach. But the asymmetry holds; passing them proves nothing, and failing both is close to decisive. Most of the money in this record was spent by programs that failed both. The first question gets defended against the obvious objection later, and the pair becomes twenty you can put to a real proposal.

## PART I

# What Actually Happened

## 1. What Changed, and What Didn't

The problem is older than any technology we have thrown at it. Around 1900 BCE a Babylonian field sale was recorded in cuneiform and authenticated with a cylinder seal, an object whose impression stood for a person's assent. Henry V issued safe-conduct letters in 1414. England standardized birth certificates in 1837, Prussia formalized driving licenses around 1903, the League of Nations standardized the photographic passport in 1920, and the United States issued the first Social Security numbers in November 1936.



### Sealed clay contract

Mesopotamia. A cylinder seal rolled across a field-sale tablet, binding a named party to a transaction.

Metropolitan Museum of Art, CC0

Forged by anyone holding the seal



### Photographic passport

1922. The League of Nations standard of 1920 fixed the format the world still uses: a book, a photograph, an issuing authority. Public domain

Only as good as the issuing state



### Nansen passport

1929. Identity for people no state would vouch for, honoured only because other states agreed to accept it.

Wikimedia Commons, CC0

Worth exactly what verifiers granted it



### Social Security number

From 1935. An identifier issued for one purpose that became the de facto national identity number for many.

US National Archives, public domain

Borrowed as an identifier, then used as a secret

Four identity systems separated by nearly four thousand years, and the red line under each is its characteristic failure. Between them they cover the whole ancient list: forgery, dependence on an issuer, dependence on other parties agreeing to honour the thing, and an identifier quietly acquiring uses nobody authorized. Not one is a failure of the artifact. The seal is well made, the passport is well printed, the card is unambiguous. Everything that goes wrong is institutional, and every item on that list is still live.

Each struggled with the same four things. Forgery, loss, administrative delay, and verifying a person across a jurisdictional boundary. Digital identity does not solve them so much as change which of them is hard.

It is worth laying the sequence out properly, because the same three questions get different answers in each era. Who controls the identity, how it is verified, and who is accountable when it is wrong, and the current generation is best understood as an attempt to take one era's answer to the first question and another era's answer to the second.

| FORM                                   | WHO CONTROLS IT                                                                                       | HOW IT IS VERIFIED           | WHO IS ACCOUNTABLE        | CHARACTERISTIC WEAKNESS |
|----------------------------------------|-------------------------------------------------------------------------------------------------------|------------------------------|---------------------------|-------------------------|
| <b>Relational</b><br>to ~1800          | The community<br><i>"The village knows who you are."</i>                                              | Recognition, reputation      | Social norms, diffusely   | Bias, does not travel   |
| <b>Documented</b><br>1837–             | Issuer issues, bearer holds<br><i>"You carry papers; others inspect them."</i>                        | Physical inspection          | The issuing institution   | Forgery, loss, delay    |
| <b>Enterprise / platform</b><br>1960s– | The platform owns accounts<br><i>"You borrow an account from each website."</i>                       | Database lookup              | The service operator      | Breach, vendor lock-in  |
| <b>Federated</b><br>2002–              | Shared across institutions<br><i>"Airlines honour each other's loyalty cards."</i>                    | Assertion exchange           | Contested; usually the RP | Uneven assurance        |
| <b>Holder-controlled</b><br>2017–      | The holder, issuers endorse<br><i>"A programmable credential: portable, auditable, policy-bound."</i> | Cryptographic proof, offline | Distributed by policy     | Key loss, no override   |

Each form solved its predecessor's weakness and introduced a new one. None retired the form before it, and all five are in production today.

The accountability column is the one that decides architecture, and it is the column that gets least attention at design time. Notice that it becomes less clear as you go down, not more. The sequence's advocates usually claim the reverse.

Two definitions worth fixing before going further, because loose use of both words causes real confusion in procurement documents.

Identity, operationally, is a set of assertions about a subject that can be proven in a specific context and maintained over time, and every clause in that sentence is doing work. Assertions, not an essence. Proven in context, because an assertion adequate to rent a bicycle is not adequate to open a brokerage account. Maintained over time, because an assertion true at enrollment and never revisited is a claim about the past.

Trust is the harder one, because in this field the word has come to mean roughly the opposite of what it appears to mean, and almost every institution in this record has built its vocabulary on the wrong sense. In security engineering the term is an admission of exposure, not a compliment. Ross Anderson uses the NSA definition; a trusted system or component is one whose failure can break the security policy, while a trustworthy one is one that will not fail. The two are independent, which is why trusted but not trustworthy is a coherent and unfortunately common description of a working system.

Now read the field's vocabulary back through that definition. A trusted third party is a party that can betray you. A trust anchor is a single point whose compromise compromises everything beneath it. A trust framework is a list of parties a verifier has agreed to be vulnerable to, and a trust register is that list with a URL. The United Kingdom's scheme is governed by a Digital Identity and Attributes Trust Framework, and the European regime publishes trusted lists. In every case the word reassures the reader while describing exposure to the engineer.

This is not pedantry, because the misreading has consequences that surface twice later. A regulator will not let a bank delegate its obligation to know its customer. Under the engineering definition that rule stops looking like obstruction and starts

looking like precision; to accept somebody else's verification is to become vulnerable to them, and the law is declining to let the bank pretend otherwise. And section 4's observation that three companies are now the root of trust for consumer identity reads differently once trust means exposure. It is not a statement about confidence but a count of how many parties can break everyone else's security policy, and of how few of them anyone can hold to account.

Trust in the second sense, the ordinary one, is also not a thing a system has. It is a measurement that decays and has to be renewed. A trust framework certifying at admission and re-certifying annually is measuring something once a year and asserting it continuously for the other 364 days, which is the gap the third part of this post is about, and One Login is what it looks like when the gap is a supplier's expiry date.

With those in place, the shift digital identity actually represents is easier to state. It is not that digital identity is more trustworthy, but that it is more formalized. Rules implicit in human process become explicit and testable. A clerk glancing at a photograph, a bank manager recognizing a customer, an official deciding a seal looks right, all of it written down and executed. That creates real capability and a new class of failure, because an implicit rule degrades gracefully and an explicit one either runs or does not.

## 2. The PKI Era, and Building the Wrong Half Well

The first era, from the early 1990s to roughly 2005, contains the category error that echoes through everything after it, which is treating identity as a cryptography problem rather than a service-delivery and governance problem. Governments and standards bodies invested heavily in PKI, smart cards and X.509-rooted trust, and built infrastructure that was, by the standards of the day, technically excellent.

The European Digital Signature Directive of 1999 is the cleanest illustration. It created legal recognition for electronic signatures across the Union, and a limited mutual recognition for qualified ones, and then left the operational questions to standards work and national implementation. Each member state built a stack that worked at home, and a signature with legal standing in one country and no reliable way to be processed in the next is worth approximately nothing. The Union spent the following twenty-five years discovering that recognition and interoperability are different things.

The United States built the Federal Bridge CA, operational as a prototype in 2000. It is routinely cited as the era's emblematic failure, and the record does not support that. Its scope was interoperability between federal agency PKIs and the entity domains that transact with them, and within that scope it worked. Commercial bridges cross-certified, CertiPath for aerospace and defense supply chains and SAFE-BioPharma for pharmaceutical exchange with the FDA and DoD, because their members needed to do business with agencies that required the credentials. It never reached commercial use where no agency was a party, and that was never what it was for. What looks from a



distance like a failed general-purpose PKI is a narrow one that did its job, which is the same shape as the mandated programs below. Where the era succeeded, it succeeded narrowly and by mandate. PIV, established under HSPD-12 in 2004 for civilian federal employees, and CAC, deployed to more than four million Department of Defense personnel, both worked. The use case was specific, enforcement certain, scope bounded. And the part that matters here, the party that benefited from the credential was the party that paid for it and required its use.

Estonia is the era's genuine exception and is routinely misread, since the technical implementation was standard PKI. What differed was that identity was embedded from the start in services citizens actually wanted, among them tax filing, prescriptions, business registration and voting. Estonia did not build an identity system and then look for uses. It built services and made identity the way you reached them. The cryptography was not superior; the sequencing was.

The sequencing lesson gets quoted more often than it gets understood, though, and the shortened version of it is actively harmful. Start with one high-value transaction is sound advice about launch order and useless advice about architecture, and the two questions are not the same question even though they are answered at the same meeting.

Launch order asks which transaction you go live with, and the answer is one, painful and frequent, with a verifier that already wants it. Architecture asks what the credential must be able to express, and that question is settled by the whole space of uses you will eventually be asked to serve, not by the first of them. Each use case brings its own assurance level, its own set of claims, its own lifecycle events and its own workflow, and those requirements land on the data model, the binding, the revocation semantics and the proofing rules. Get them from one use case and you have fitted the foundation to that case. It will work, and it may be the only thing that ever works.

The United Kingdom is the clearest illustration of both ends of this. Verify's proofing was built around documentary and credit-file evidence, which describes an adult with a settled UK financial history rather well and describes a farmer, a young person or a non-UK national badly, so the evidence model became a ceiling on who the system could serve at all. The exclusion figures in section 6 are not a usability failure downstream of a good design. They are the design, meeting people it was not surveyed for. One Login then went the other way, narrowed hard, got its completion rates up, and is now being asked to underpin a wallet, right-to-work and right-to-rent checks and criminal record disclosure. Whether the choices that made the narrow thing work will carry that is precisely the question nobody can answer from inside the narrow thing.

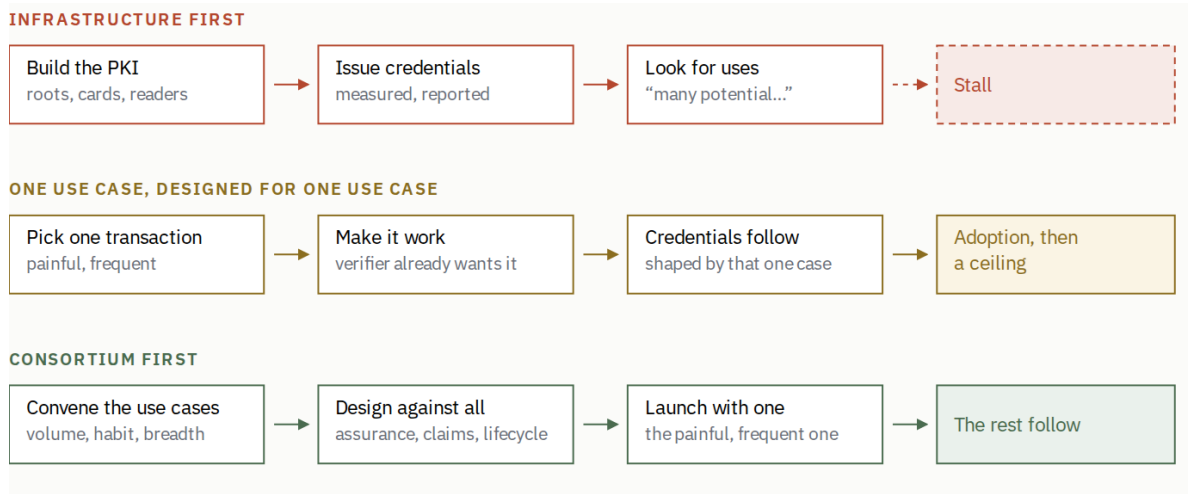
The requirement is a consortium, assembled before design, because what you need is the actual parties telling you what their workflows and lifecycles require, and those are not inferable. Three roles have to be present.

Volume. Somebody who brings holders in bulk, which in practice means banks, large employers or a benefits agency. This is the role everyone remembers to invite, and on its own it produces a credential that a lot of people have and nobody carries.

Habit. Something boring and recurring, and this is the role that gets left out because it looks beneath the ambition of the program. A fishing license. A library card. A parking permit. A quarterly benefit check-in. Low stakes, low glamour, and it brings the subscriber back, which is the difference between a credential somebody was issued and a credential somebody has. Enrollment is not adoption.

Breadth across organizations. If there is a government use case, it must come from more than one body, because Conway's law applies to credentials. A credential specified with one department in the room will encode that department, meaning its data model, its proofing thresholds, its idea of what a person is and which of their attributes matter. Every other department then finds the fit is subtly wrong, and subtly wrong is unfixable once section 18's choices have set. Two agencies that disagree with each other at design time are worth more than one that agrees with itself, because the disagreement is the requirement surfacing while it is still cheap.

This is, incidentally, the sharpest way to state what the Scandinavian and Belgian systems in section 5 actually did. They were not government programs that found bank partners. They were consortia from the start, with the volume, the habit and the breadth in the room before the architecture existed.



Rows two and three launch on the same transaction. They differ in who was in the room before the first credential was issued, and that difference is invisible until somebody asks for the second use case.

The Federal Bridge, the 1999 Directive and NSTIC ran the top row. The bank consortia in section 5 ran the bottom one, and Estonia came close by embedding several services from the start rather than one. The middle row is the trap that looks like the advice: launching with a single transaction is correct, and designing for only that transaction is how the first use case becomes the last.

Even Estonia demonstrates the other half of this post's argument. In 2011 roughly 120,000 faulty cards were distributed. In 2017 a vulnerability affected approximately 760,000 cards issued since 2014, forcing a nationwide eID freeze. Sequencing the

services right did not include modelling what happens when the credential fails for the whole population at once, and that turned out to be a separate piece of work nobody had done.

### 3. Federation, and the Trade Nobody Wanted to Make

From roughly 2005, Microsoft, the Liberty Alliance and the Higgins project promoted federation and user-centric identity as the answer to the PKI era's failures. Separate the identity provider from the relying party, and exchange assertions rather than shipping cards. Correct in theory, and it failed in practice because it treated federation as a protocol problem when it was an incentive problem.

InfoCard, later Windows CardSpace, is the case worth dwelling on. It presented identities as selectable visual cards and rested on Kim Cameron's Laws of Identity, which set out user control, minimal disclosure, justifiable parties and consent. The minimal-disclosure cryptography usually associated with it arrived later and never really arrived at all: Microsoft acquired Credentica in March 2008, two years after CardSpace shipped, and announced that Stefan Brands' U-Prove work would be incorporated into CardSpace and Windows Communication Foundation. CardSpace was discontinued in 2011. So the design most often held up as the privacy-correct road not taken never shipped the part that would have made it so. Those principles were right then and are still right. The system died of Windows-specific infrastructure and developer complexity, while OAuth arrived in 2007 and OpenID Connect in 2014 with a model a developer could integrate in an afternoon.

OAuth was not technically superior. In several respects it was considerably less sophisticated. What it did was solve the adoption problem, by being narrow and cheap to implement.

The trade has a bill, and it came due. By centralising authentication at Google, Microsoft and Facebook, OAuth enabled precisely the business model InfoCard was designed to prevent. The tidy summary is that InfoCard had the right principles and the wrong adoption theory while OAuth had the right adoption theory and abandoned the principles. That is true as far as it goes, and it is the framing most of the decentralised identity movement operates under.

Follow it through, though, because it is not the clean synthesis it looks like. What made OAuth adoptable was not only simplicity. It was that the parties doing the integrating, the relying parties on the verifier side, got something immediately. A signed-in user, no password database, no account recovery burden. Simplicity mattered because it lowered the price of a thing they already wanted. A decentralised credential presented to the same verifier offers no equivalent, because there is no password database to escape and no sign-up funnel to shorten. Copying OAuth's simplicity without copying the reason verifiers wanted it copies the wrong variable.

One more thing this era establishes. OAuth and OIDC are widely adopted and not interoperable in any strong sense. Each major provider carries its own scopes and quirks, and the behavior of dominant implementations becomes the de facto specification everyone else must match, so standards produce commonality. Without conformance testing and enforcement they do not produce compatibility.

| WHAT EACH DESIGN OFFERED, AND TO WHOM     |                                          |                                      |                                          |
|-------------------------------------------|------------------------------------------|--------------------------------------|------------------------------------------|
|                                           | PRINCIPLES                               | DEVELOPER COST                       | WHAT THE RELYING PARTY GOT               |
| <b>InfoCard / CardSpace</b><br>2006       | Correct, with consent minimal disclosure | High, Windows stack unfamiliar model | Nothing it did not already have          |
| <b>OAuth / OIDC</b><br>2007               | Abandoned, assertion flows to the IdP    | An afternoon                         | No password database, no recovery burden |
| <b>Decentralised credentials</b><br>2017– | Claimed. Available, rarely the default   | Low, and falling                     | Still nothing it did not already have    |

**The synthesis copies the wrong column.**  
Simplicity was not why OAuth won. It was that simplicity made cheap a thing the verifier already wanted.  
And the third row's principles are a capability, not a deployment. Selective disclosure is supported and seldom the default; unlinkability is mostly handled by issuing batches of single-use credentials rather than cryptographically.

Read the right-hand column, not the left. It is the only one that predicts adoption, and it is the only one the current generation has not changed.

## 4. When Platforms Became Infrastructure

Somewhere in the 2010s the operative question stopped being which standards body would define identity and became which platform would ship it. This era gets less attention than it deserves, partly because it produced no flagship program to write a post-mortem about.

Two Microsoft specifications make the point, and I should say before making it that I am an author of one of them. GIDS, published in 2010, was a perfectly reasonable smart card specification, and it got the best distribution available on the desktop; a class minidriver shipped inbox with every Windows from 7 SP1 onward, so a GIDS card works with no middleware, no vendor driver and no install. Its design goal was remote deployment: credentials provisioned to a device without the physical issuance station that PIV requires, which is the constraint that makes PIV expensive to extend beyond a badge office. It still went essentially nowhere beyond Microsoft's own stack, where it backed Windows virtual smart cards.

That is worth sitting with, because distribution was not the missing ingredient. GIDS had it. What GIDS never had was a verifier outside Microsoft's own products with a reason to want a GIDS card rather than the password, token or federated login it was already using. FIDO2 and the passkeys built on it had both halves; they shipped in every browser and operating system rather than one, and they handed the accepting party something it wanted on day one.

The consequential shift underneath is that Apple, Google and Microsoft became de facto roots of trust for consumer identity without any deliberate policy decision to that

effect. Device attestation, secure enclaves, platform wallet distribution and the browser's credential APIs are now the substrate everything else sits on. When a state issues a mobile driving license today, the credential's real distribution mechanism is a wallet that ships with the phone. When a bank deploys strong authentication, the enrollment path runs through platform biometrics. No treaty established this. It happened because the platforms controlled distribution and everyone else did not.

*Standards bodies decide what is possible. Platforms decide what is deployed. Thirty years of the record turns on which of those two a program had.*

Passkeys deserve a precise reading here, because they are routinely offered as evidence that good design wins in the end, and that is not quite the lesson. Passkeys are succeeding at something identity programs have found impossible, and they are not an identity system. They authenticate a returning user rather than establishing who a person is, and they solve no part of the proofing problem. What they demonstrate is the adoption mechanic in isolation. The verifier gets an immediate, self-interested benefit in the form of no password database, less credential-stuffing exposure and fewer recovery tickets, and the platform supplies distribution. Neither a mandate nor a trust framework was involved anywhere.

Making platform vendors the root of trust for consumer identity means, in the sense section 1 set out, that three companies can now break almost everyone's security policy, subject to their commercial priorities and to no identity-specific accountability regime. That is the same mechanism seen from the other end.

Acceptance is the scarce input. Distribution is how acceptance gets supplied at consumer scale, and three firms own it. So the thing that decides whether any identity system exists is, for consumer credentials, privately held by a duopoly and a distant third, and no identity program reaches its own users except by their permission. The platforms did not capture the identity layer by building better credentials. They captured it by owning the only channel through which acceptance could be manufactured.

That produces an uncomfortable symmetry with something I criticise later. Section 20 objects to eIDAS Article 45 on the grounds that it compels acceptance rather than earning it, and compelled acceptance is not self-sustaining. Platform-supplied acceptance is granted rather than earned, revocably, by firms answering to shareholders and not to an electorate, and it can be withdrawn through an API deprecation notice with more finality than any regulator could manage. Both are acceptance by fiat. The difference is that one fiat is at least reviewable by a parliament.

Two things distinguish a platform from a state, and together they make a stronger case than the one just made. The first is that users pick platforms. The browser is called a user agent for a reason, and a person who dislikes Apple's terms can buy an Android handset, which is not an option anyone has with their government. Exit is weak, slow

and expensive, and it is not nothing; a captured channel you can leave is a different object from one you cannot.

The second is the one that ought to be obvious from section 5 and was not obvious to me. Platforms are verifiers. Apple authenticates people to unlock devices, authorise payments and reach accounts, and it carries real consequences when that goes wrong. So a platform building authentication is the party carrying the verification obligation building the thing, which is precisely the alignment that section 5 argues explains the Nordic and consortium outcomes. Passkeys work for the same structural reason BankID works. On this post's own criteria that is the healthiest possible arrangement, and it is inconsistent to celebrate it in Stockholm and be uneasy about it in Cupertino.

What the argument does turn on is scope. The alignment holds while the platform is verifying for purposes it is answerable for. It weakens as the credential is borrowed for things the platform does not itself verify and bears no consequence for, which is what a state-issued identity carried in a platform wallet is. At that point the platform is supplying distribution and assurance for somebody else's obligation, the incentive that made it trustworthy is no longer engaged, and the concentration objection lands with full force. Whether the current generation stays on the safe side of that line is not something the record can tell us, because it has only just started crossing it.

Platform distribution is still the right answer for mDLs and passkeys, since the alternatives did not work and a working system beats a principled one nobody accepts. It should be recorded as what it is. The field solved its hardest problem by outsourcing it to three companies that were never asked to take the job and cannot be made to keep it.

TWO SPECIFICATIONS FROM THE SAME COMPANY, BOTH SHIPPED IN THE PLATFORM

|                                                                                                                                                                                                                                                                                                                      |                                                                                                                                                                                                                                                                                                                       |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>GIDS · 2010</b></p> <p><b>Distribution</b><br/>Class minidriver inbox in every Windows since 7 SP1.<br/>No middleware. Built for remote deployment.</p> <hr/> <p><b>What a verifier got</b><br/>Nothing it was not already doing another way</p> <hr/> <p>Used inside Microsoft's own stack. Nowhere else.</p> | <p><b>FIDO2 / passkeys · 2018</b></p> <p><b>Distribution</b><br/>Browser and operating system, across every vendor, not one of them.</p> <hr/> <p><b>What a verifier got</b><br/>No password database, fewer recovery tickets, less credential-stuffing exposure</p> <hr/> <p>Adopted without a mandate anywhere.</p> |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**Distribution is necessary and it is not sufficient. GIDS had it and still failed.**

The difference is the lower row. A credential that ships everywhere and offers the accepting party nothing is a credential nobody asks for, which is the same finding as OAuth against InfoCard, arriving from the opposite direction.

Distribution beats specification, until GIDS. It had the best distribution available on the desktop and went nowhere, because shipping a credential to every holder does nothing if no verifier wanted one.

## 5. The Institutional-Trust Models

Scandinavia, the Netherlands and Singapore produced the highest sustained adoption in the record, and the usual explanation, small homogeneous populations with high institutional trust, is true, insufficient, and slightly self-serving when offered by



programs that failed elsewhere. The structural feature is more specific and more portable than the cultural one.

Sweden's BankID, launched in 2003, and Norway's equivalent a year later were built by banks. Banks carry statutory identity obligations under AML rules and absorb fraud losses directly. They were, in the vocabulary of this post, the verifier and the builder at once. That collapses the asymmetry the rest of the record suffers from. There is no gap between the party who funds issuance and the party who decides acceptance, because they are the same institution, and it does not need to be persuaded to integrate with itself.

Denmark complicates the section, and it is the one that shows mandates working. NemID did not emerge from the banks. The Danish government commissioned a study on digital signatures in 1999, NemID grew out of that, and it was state-funded rather than competed for in a market. Then in November 2014 Denmark required citizens to receive public-sector post through a digital document box, which in practice required NemID to open. Adoption followed, and MitID has inherited it as the required standard across banking, government and much of the private sector. The Netherlands ran two schemes alongside each other rather than merging them. DigiD is the government login for public services; iDIN is the bank-backed credential for private use, offered in a government pilot as an alternative a user could pick rather than folded into DigiD. Neither tried to manufacture a new supply of institutional trust, and both reused one that existed. Singapore's Singpass was government-led from 2003, and what distinguishes it is less its architecture than that it has been continuously iterated for two decades, including a rapid pandemic-era expansion. Which is to say it has a funded operating model, and that is the subject of Part III.

It is worth putting numbers on how well, because the section otherwise asserts success without measuring it. Sweden's BankID reports on the order of 8.5 million users, which is near-universal among Swedish adults, running something like 19.5 million authentications a day. Norway's serves upward of four million. DigiD passed 13 million. Singpass reports 97 to 99 per cent adoption across roughly 4.5 million users, more than 350 million transactions a year against 2,000-plus services, and something the rest of this record conspicuously lacks, namely a benefits figure of around \$385 million that its own government is willing to publish and stand behind. Set that against Verify, where the National Audit Office could not replicate the benefits estimate current in 2019, and where a later Cabinet Office assessment in 2022 put lifetime benefits at £485.3 million.

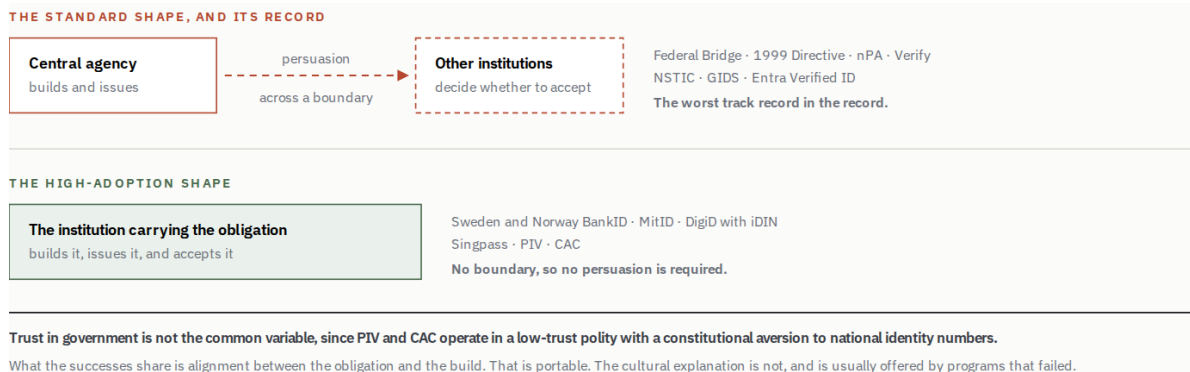
Belgium is the entry that makes the pattern hardest to explain away, and it arrived later than the rest. itsme launched in 2017 as a consortium of the major Belgian banks and telecom operators, the parties already carrying AML obligations, PSD2 strong-authentication duties and SIM-registration requirements. It now reports roughly 7.5 million users, more than 80 per cent of Belgian adults, and over a million actions a day, and it reached that without a government mandate anywhere in the story. It grew

because it was the fastest way into a bank account, and everything else followed the bank. In December 2025 it acquired iDIN, so the Dutch and Belgian entries in this record are now the same company.

The pattern has a fourth member the section title does not suggest. Apple and Google carry a real obligation to authenticate their own users, for device access, payments and account recovery, and they built the authentication that discharges it. Passkeys are the same shape as BankID with a different institution in the role, which is why section 4 treats platform distribution as an outcome rather than an accident, and why the concentration objection there has to be argued rather than assumed.

Now the objection, because this cluster is often used to argue that identity is culturally determined and therefore that nothing transfers. These systems share something with PIV and CAC, which operate in a country with famously low institutional trust and a constitutional aversion to national identity numbers. In both cases the institution bearing the verification obligation is the institution that built the system. Trust in government is not the common variable; alignment between the obligation and the build is.

That is a portable finding rather than a cultural one, and it suggests something uncomfortable about the standard national-program shape. A central agency building a credential for other people to accept has the worst track record in the record, and it is also the structure most governments default to.



The upper shape is what most governments default to. The lower shape produced every sustained high-adoption result in the record, in both high-trust and low-trust societies.

### KEY LESSON

What the high-adoption systems share is not social trust. It is that the party carrying the verification obligation built the system.

## 6. The Bureaucratic Decade

The 2010s produced the most expensive and best-documented failures in the record. Identity was treated as a program to be managed rather than an ecosystem to be built and enabled, and issuers assumed that controlling the lifecycle, meaning enrollment



and credential management and revocation, would produce adoption. That confuses a necessary condition, having credentials, with a sufficient one, having a reason to use them.

The usual formulation of that error is that identity should be treated as an ecosystem to be enabled rather than a program to be managed, and the usual formulation is not quite enough. Enabling is what NSTIC did. It funded pilots, convened participants, published a strategy and waited for the market to form, on the theory that government could not dictate a solution and should therefore create the conditions and stand back. Nothing formed. An ecosystem is not a thing that appears when the obstacles are removed; it is a thing somebody assembles, which means convening the parties before the design is fixed, deciding whose obligation the credential discharges, and paying for the parts nobody else will fund. Enabling is the passive half of the job and it is the half that gets budgeted.

### **Germany, and friction without a payoff**

The nPA launched in 2010 with a secure chip and a sound online identification function. Activation originally required an in-person step at a citizens' office, dedicated middleware in the form of AusweisApp, and a card reader the holder bought. Then in July 2017 Germany changed the default and began activating the eID automatically on collection.

What happened next is the clearest natural experiment in this record, and it is worth reading slowly. By October 2024 the government could report roughly 70.4 million cards with the eID function activated, more than 97 per cent of the cards in circulation. Over the same period, actual use went from just under ten per cent of the population in 2022 to 22 per cent in 2024, and only 39 per cent had gone as far as setting their own PIN. An independent survey taken in October 2024 found just 35 per cent of adults believed they had activated it at all, and six per cent did not know the function existed.

Read those numbers as two different measures rather than one series. Automatic activation made the eID function technically available on nearly all current cards; awareness, PIN setup and actual use remained much lower. Availability and use are different measures, and the gap between them is the finding. The issuer controlled availability completely and use hardly at all.

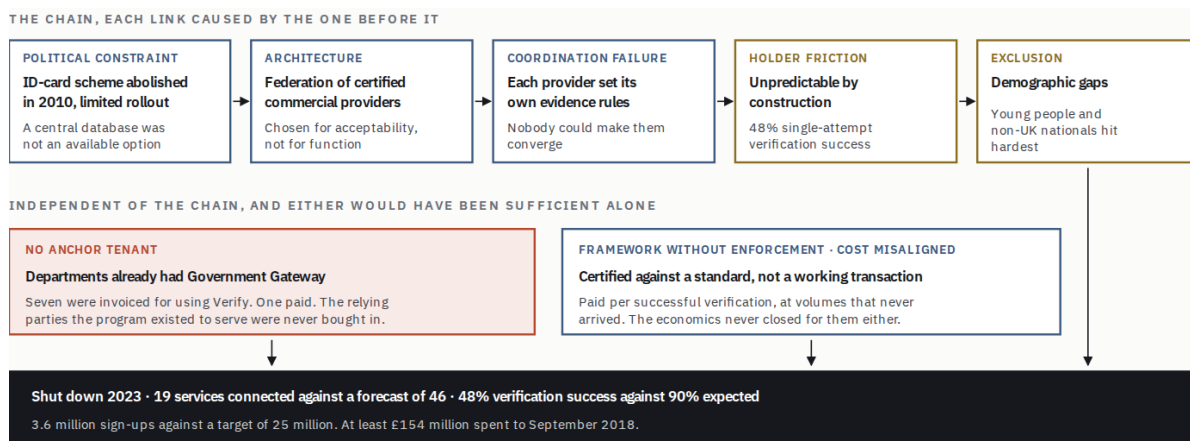
Germany is not short of technical sophistication, and the nPA demonstrates a pure economic misalignment instead. The holder paid, in money and friction, for a credential whose benefits accrued mostly to verifiers, and the number of accepting services never justified the outlay. The Max Planck study naming the 35 per cent figure reaches the same diagnosis independently and calls it a dilemma of mutual conditionality; firms will not integrate the eID because too few people use it, and too few people use it because so little accepts it. Many public bodies chose ordinary

hardware tokens for staff authentication rather than the national card. Government agencies decided their own national credential was too cumbersome to use. Smartphone-stored IDs arrived in 2025, still carrying proprietary constraints.

## The United Kingdom, and seven failure modes in causal order

GOV.UK Verify is the best-documented failure available and the reason this post uses multiple tags per program rather than a single cause, because it did not fail in one way. It failed in seven, and the order between them is the finding.

The starting constraint was political. The Identity Cards Act of 2006 created a card and a national register, a limited rollout issued cards, and the coalition government abolished both in 2010. A central register was not available as a design option after that. So Verify was built as a federation of certified commercial identity providers, an architecture chosen for political acceptability rather than function. That created a coordination problem, because each provider set its own evidence requirements and approval thresholds, which made the holder experience unpredictable by construction rather than by poor execution. Unpredictability produced a 48 per cent single-attempt verification success rate, a measure the NAO cautioned excluded people who abandoned before reaching provider confirmation, and demographic exclusion that fell hardest on young people and non-UK nationals. Certification was against a standard rather than against a working transaction, so compliance and utility diverged. Providers were paid per successful verification at volumes that never materialised, so the economics never closed for them either. And underneath all of it, departments had their own alternatives, notably HMRC's Government Gateway, and no mandate obliged them to switch, so the anchor tenant never existed at all.



### Why single-cause post-mortems mislead.

The onboarding experience is the fourth link, and it is the one the program was criticised for. Fixing it would have left the political constraint, the coordination problem and the absent anchor tenant untouched, and any one of those three was enough on its own.

Seven modes, and the order between them is the finding. This is the case that makes multi-tagging necessary. A record listing only “poor user experience” would describe a symptom four links downstream of the decision that caused it.

The delivery numbers followed. By early 2019 nineteen services had connected against a 2016 forecast of 46 by March 2018, and eleven of those nineteen still offered an alternative way to sign in. Verification succeeded 48 per cent of the time against a projection of 90. Sign-ups stood at 3.6 million against a target of 25 million by 2020, with the National Audit Office projecting about 5.4 million by the time central funding stopped. It limped on through the pandemic and was shut down in 2023.

The supply side went the same way, which is the half usually left out. Certified identity providers withdrew, PayPal and Verizon among them, so the federation was losing the very participants whose plurality was the design's justification. A scheme built on commercial providers competing to verify people, in which providers exit and departments decline to pay, is not a market with adoption problems but a market that did not form.

The most telling number in the NAO investigation is none of those. Seven departments were invoiced for their use of Verify. One paid. HMRC settled £6.7 million; between 2016-17 and 2018-19 no other department paid anything, despite being billed for a service they were using at a subsidised rate. A program cannot ask for a clearer signal that the acceptance side was never bought in, and it kept operating for four more years after receiving it.

A caution on the money, because the figures get quoted carelessly in both directions. The Cabinet Office's own accounting officer assessment records £485.3 million of benefits against £233.38 million of cost through 2021/22, a benefit-cost ratio of 2.1 to 1, which on its face is a positive return rather than a failure. Set against that, GDS's original business case forecast £873 million of benefits for 2016-17 to 2019-20 and revised it down to £217 million, a 75 per cent cut. So the shortfall is against the projection, not against zero.

And there is a wrinkle that should stop anyone leaning hard on either figure. GDS classified these benefits as non-cash releasing, its own accounting term for efficiencies that do not actually reduce a departmental budget. A significant proportion of them are avoided building costs, an estimate of what departments would otherwise have spent constructing their own identity systems, claimed at £37 million a year. The NAO's finding on this is unusually blunt; on the evidence made available to it, it could not replicate or validate the estimated benefits. The benefits number is soft in both directions, and Verify's economics were never independently established either way, which is itself the point. A program whose central benefit claim was money other people did not have to spend was always going to struggle to show anyone a reason to accept it.

One Login replaced it in 2023 with narrower scope and simpler onboarding, reaching more than 13 million users by 2025. It also lost DIATF certification in April 2025, five months after obtaining it, when its biometric supplier iProov let its own certification lapse after a routine review and One Login was automatically struck from the register.

Recovery took nine months. iProov recertified in October 2025, One Login returned to the register in late January 2026, and remediation contracts for cybersecurity and technical architecture were let with a combined potential value of about £18 million. GDS has since built systems to track the certification status of its supply chain.

That sequence is worth more than the embarrassment it caused. A single supplier's administrative decision, taken for its own commercial reasons, removed the legal standing of the credential behind more than fifty public services, and restoring it took most of a year, with nothing about the identity system having changed. Learning from one failure does not immunise against the next, and a modest amount of continuous supplier verification would have caught this before it happened.

### **The United States, and the chicken and egg never solved**

NSTIC took a more sophisticated approach in 2011, recognizing that government could not dictate a solution, and funded pilots to seed a private ecosystem instead. It failed for a reason that should now be predictable, which is that there was no anchor tenant. Without large services requiring NSTIC credentials there was no reason for identity providers to invest, and without identity providers there were no credentials for verifiers to accept. Intermediaries such as Kantara and the OpenID Foundation attempted to mediate and faded for lack of sustained funding, since coordination bodies cannot solve free-rider problems while being free-rider problems themselves. Login.gov emerged later with a narrow, unambitious scope and works modestly well.

### **India, and the problems scale brings**

Aadhaar is, by adoption, the most successful digital identity system ever deployed. Over 1.3 billion enrollments, real effect on benefit delivery, and financial inclusion for hundreds of millions of people without prior documentation. It also demonstrates that operational success and sustainable governance are different achievements. Concerns about purpose limitation, exclusion and oversight accumulated until the Supreme Court intervened in 2018 to limit mandatory use. Governance problems do not dilute at scale. They concentrate.

## **7. Decentralisation Meets a Constraint It Cannot Argue With**

Decentralised identifiers, verifiable credentials and key event receipt infrastructure reframed identity around holder control and selective disclosure. As a model this is a genuine shift, from identity as a service institutions provide to identity as a capability individuals hold, and an honest attempt to keep InfoCard's principles while learning from OAuth's adoption.

As a deployment it is thinner than that, because the privacy claims are frequently stated as achieved when they are only available. Selective disclosure is supported by

SD-JWT and mdoc and is seldom what a verifier actually requests, since the reader decides what to ask for and the incentive runs toward asking for more. Unlinkability is the harder property and is mostly not being solved cryptographically; the practical answer in the European work is to issue batches of single-use credentials, which limits correlation at the cost of moving the problem into issuance and reissuance. And several mobile driving license deployments support server retrieval, which tells the issuer where the credential was presented, the precise thing the model was supposed to prevent. Utah's design minimises that, which is worth saying only because it is unusual, and a design choice is not yet a deployment.

The entry in the ledger is that the principles were restored to the specification and have yet to be restored to the deployments, and that the gap between those two is exactly the kind of thing this post argues nobody funds after launch.

Some of it is working. Mobile driving licenses under ISO 18013-5 are the clearest success of the last decade, and how they got there is instructive. Apple and Google adopted the model into their wallets from 2021, and the TSA began accepting mobile IDs at participating airports in 2022. TSA acceptance matters more than any specification in the family, because it is the first large-scale verifier creating actual demand. Travellers get through security without a physical card, which pressures states to issue and vendors to conform. Without it, mDLs would plausibly still be a standards exercise.

Some of it cannot be classified from the outside. Microsoft's Entra Verified ID reached public preview in 2022 with strong technical capability, market position and genuine commitment, and it remains an active product with continuing investment; Verified ID account recovery reached general availability in 2026 and new integration partners keep arriving. What has not appeared is public adoption data that would let anyone compare its ecosystem use with Microsoft's established federation products, and wallet interoperability has not visibly materialised at scale. The instructive part stands either way. Even Microsoft's platform power has not visibly manufactured ecosystem demand, because enterprise customers could not see what the credential bought them over the federated identity they already ran.

And some of it runs into a wall that is not technical at all. Banking regulation under AML and KYC rules keeps the institution responsible for its customer due diligence. Current UK guidance does let a regulated firm use a certified digital verification service to fulfil the identity-verification component of that duty, but the firm remains responsible for the adequacy of the overall determination and must still carry out the customer-risk assessment, any enhanced diligence, the purpose-and-nature assessment and the record-keeping around it. So a credential removes a component of the work rather than the responsibility, and usually less duplicated effort than the pitch assumes. The same logic operates in government benefits, where accountability for improper payments falls on the agency, and where pandemic-era fraud losses of \$647 million in Washington state alone, and a federal unemployment insurance figure the

GAO later put between \$100 billion and \$135 billion, have made agencies acutely unwilling to rely on verification they do not control.

THE SAME TECHNOLOGY FAMILY, THREE OUTCOMES, ONE VARIABLE

|                                                                                                                                                                                                         |                                                                                                                                                                                                                     |                                                                                                                                                                                                                                         |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>mDL · ISO 18013-5</b></p> <p><b>A verifier already needed this</b></p> <p>TSA checks identity at a checkpoint whether or not mDLs exist. Platform wallets solved distribution.</p> <p>Working</p> | <p><b>Entra Verified ID</b></p> <p><b>No verifier needed it</b></p> <p>Capability, market position and real commitment. No public evidence of gain over the federation enterprises ran.</p> <p>No anchor tenant</p> | <p><b>Bank KYC credentials</b></p> <p><b>A verifier wanted it and could not</b></p> <p>The firm stays responsible for its own determination, so the credential removes far less work than the pitch assumes.</p> <p>Liability floor</p> |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

The protocols are the same in all three. What differs is the verifier's position, wanting it already, not wanting it, or wanting it and being forbidden to benefit. No design choice available inside the middle or right-hand box converts it into the left-hand one.

Arguments about whether decentralised identity “works” usually collapse these three cases together. They have almost nothing in common except the specification stack.

*These are not problems better protocols solve. They are the conditions under which any protocol has to operate, and they decide which architectures are available before a single design choice is made.*

The consequence is that in high-stakes regulated contexts, decentralised systems tend to converge on something resembling the centralised solution, with added key-management friction for the holder, more dependence on device and connectivity, and less institutional ability to override during an incident. The next two sections name that constraint and draw the boundary where it stops applying, because it does stop.

## 8. Assurance Levels and the Convergence Decade

The 2020s brought two developments the earlier eras lacked, and they pull in opposite directions. One is a shared vocabulary for how much assurance a transaction actually needs. The other is a body of evidence that identity systems exclude people, at scale, in ways the assurance vocabulary can make worse if applied carelessly.

### The assurance decomposition

NIST SP 800-63 is the most useful conceptual contribution the field has made in twenty years, and its contribution is a separation rather than a scale. It splits what programs had been treating as one number into three independent questions.

THREE QUESTIONS, SET INDEPENDENTLY, PER TRANSACTION

|                                                                                                                                                                                                                 |                                                                                                                                                                                                |                                                                                                                                                                                  |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>IAL, identity assurance</b></p> <p>How well did you establish who this person is, at enrollment?</p> <p>IAL1 self-asserted<br/>IAL2 remote or in-person evidence<br/>IAL3 in-person, trained operator</p> | <p><b>AAL, authenticator</b></p> <p>How strongly did they prove, just now, that it is still them?</p> <p>AAL1 single factor<br/>AAL2 two factors<br/>AAL3 hardware, verifier-impersonation</p> | <p><b>FAL, federation</b></p> <p>How much can the assertion be trusted between the parties?</p> <p>FAL1 bearer assertion<br/>FAL2 encrypted to the RP<br/>FAL3 holder-of-key</p> |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**Why the separation is the contribution:**

A prescription refill may need high AAL and low IAL. A one-off benefits claim may need high IAL and low AAL. Treating them as one “security level” forces both upward together, which raises cost, raises abandonment, and excludes people for no gain in either. The exclusion column in the record is largely made of programs that set one level for the whole system.

The framework is widely cited and less widely applied as intended. Setting a single assurance posture for an entire program is the common error, and it is the mechanism by which a well-meant security decision becomes an access denial.

For anyone writing requirements: assurance is a property of a transaction, not of a system. A program that specifies IAL2/AAL2 across the board has not made a risk decision. It has avoided making eleven of them.

### **Inclusion, and the other half of the world**

The record in section 11 is drawn heavily from wealthy countries with mature civil registries, and it therefore encodes an assumption that does not hold for a large share of the world, namely that the population already holds foundational documents. The UN's Legal Identity Agenda and the broader digital public infrastructure movement start from the opposite premise, that lacking provable legal identity is itself the exclusion, blocking access to banking, healthcare, education, land title and social protection.

MOSIP, the open-source foundational identity platform now deployed or in progress across the Philippines, Ethiopia, Morocco and elsewhere, is the most consequential thing in this space and sits awkwardly against this post's framing. Its anchor tenant is usually the state's own benefit and subsidy delivery, which satisfies the section 12 test cleanly. Its exposure is temporal: a state adopting a mature platform faster than it can build the governance capacity to operate it is a slow failure waiting to be scheduled, and the consequences of degradation fall on populations with no alternative route to the service.

This matters for the argument and not only for completeness. Exclusion appears in the record as a contributing mode in Verify, Aadhaar, One Login and Login.gov, and in every case it was treated as a remediation item rather than a design constraint. In a high-income country that produces a bad quarter for a minister. Where the credential is the only route to a benefit, it produces something considerably worse.



**PART II**

# Why It Keeps Happening

## 9. The Lifecycle Nobody Designs For

Before the geography, a gap that runs through every program in the record and is almost never designed for. Each of these systems assumes a one-to-one binding between a credential, a device, and a living adult of full legal capacity who holds both, and that assumption is false of every human being for a substantial part of their life, and the word every matters, because treating this as an accessibility question for unusual populations is the category error that produces the architecture.

Follow one pair of people through it. A child's affairs are managed by a parent, and whose authority that is matters; in most legal traditions the parent is sovereign over the child, not the state, and a state credential that quietly relocates that authority to the issuer has made a constitutional claim while thinking it was making a technical one. Utah's SEDI framing is explicit on this point, positioning the state as endorsing rather than controlling, and supporting parents and guardians rather than substituting for them. Then the child turns eighteen and authority transfers to them. Then, decades later, the same relationship runs the other way, and the adult child is managing the parent's affairs under a power of attorney or a guardianship order.

Same two people, three regimes, and the direction of authority reverses across a lifetime.

The eighteenth birthday makes that transfer look schedulable, which is the part worth resisting, because a birthday is the most common trigger and not the defining one. A minor can be emancipated by court order, or in some jurisdictions by marriage or military service, and becomes legally capable years before the calendar predicts it. Authority can also fail to transfer at all, where a disabled adult remains under guardianship for life. It can arrive late, or partially, or be taken back when an adult loses capacity and returned if they recover. What the system has to represent is not an age threshold but a legal status that changes on unscheduled dates by judicial act, and a credential treating the eighteenth birthday as the event has encoded the common case as the only case.

Emancipation is also the cleanest demonstration that age and capacity are different questions. An emancipated sixteen-year-old is under eighteen and legally competent to act, so a credential answering how old is this person has not answered may this person act. The age-assurance schemes above answer the first, and the legislation behind them frequently means the second. Now ask what most identity architectures can represent. A credential bound to a holder, with an expiry date and a revocation list. That is a static binding with an off switch. It cannot express authority over this subject has moved to a different person, it cannot express on this date it will move back, and

revoking and reissuing is not the same operation, because the continuity of the subject is the thing being asserted.

Three populations sit inside that lifecycle, and none of them is a corner case.

Older people. The device dependence is the obvious part, and the biometric part is less discussed; fingerprint quality degrades with age, and manual work and some medications degrade it further, so the enrollment step most likely to fail silently is the one performed on the population least able to interpret the failure. Aadhaar's exclusion literature is largely about exactly this. The bitter version is that the people most dependent on the services a credential gates are, on average, the least likely to complete the flow that reaches them.

Children. A child has no independent legal capacity, frequently no device, and often should not have one. Parental authority over a child's credential is itself a claim that has to be represented and revoked, and almost nothing in the current generation represents it natively.

Age assurance is the live case, and it is worth following the logic to its conclusion because governments across several jurisdictions are legislating without having done so. There is no reliable way to verify that somebody is a child. A child arrives with no credential, no history and no independent standing, and everything about them that a system could check is asserted by someone else. So the only approach that half works runs the other way round. Verify the adults, and treat the absence of verification as the signal. Which means a policy sold as protecting children is, mechanically, a policy that requires the adult population to be enrolled and identified, which may be a trade worth making. It is not the trade being described in the legislation.

The deeper problem is that the signal does not carry the meaning the scheme needs it to carry. No credential presented has at least two causes. It can mean a child who has none. It can equally mean an adult who has one and has decided not to hand it over, which until quite recently was the ordinary condition of using the internet and is still a reasonable thing to want. The system cannot tell those apart, because they look identical at the point of decision. Whatever it does next is therefore wrong in one direction or the other. Treat non-presentation as evidence of childhood and every adult who declines to identify themselves is locked out of lawful content, which converts a privacy preference into a disability. Provide a route around it and the children use the route, which is the whole population the law was written for.

So the cost does not land where the legislation says it lands. It falls on adults who did not want to be identified, and it falls hardest on the ones with the least documentation to offer, while the motivated fifteen-year-old borrows a credential or finds the service that has not implemented the check.

And it does not work either, for a reason that goes underneath the debate. To know that somebody is a particular child you need a birth record and an affiliation to a

parent or guardian, and no state in this record issues either in a form a verifier can verify. The state produces authoritative documents about people and produces almost nothing verifiable about them. Everything else is reconstruction, inference from a face, a document photograph, a behavioral signal, and reconstruction is trivially bypassed by anyone motivated, which is precisely the population the policy is aimed at.

So age verification is a symptom of a foundational layer nobody built, arriving as a mandate on infrastructure that cannot carry it. The same absence shows up elsewhere in this post wearing different clothes; it is why pandemic unemployment fraud was as large as it was, and why agencies had no better answer than to stop trusting remote verification altogether. A failure to plan is a plan to fail.

Delegated authority. This is the structural one, and it is worth splitting in two, because the Utah SEDI work draws a distinction that most architectures collapse, whatever else happens to it. Delegation temporarily assigns duties without transferring legal responsibility, as when a parent asks a neighbour to collect a child from school. Guardianship legally transfers authority and responsibility, so a designated person may act for a child, an elderly parent or another dependent. The two have different revocation semantics, different evidentiary requirements and different durations, and a system that models one does not thereby model the other. Add powers of attorney, court-appointed deputies, carers acting for a disabled adult and an executor acting for the dead, and you have a set of ordinary legal instruments, exercised constantly, all of which require a credential to be usable by somebody who is not its subject, and holder-controlled architectures forbid that by design. A credential bound to a device and a biometric is precisely a credential nobody else can present, which is the property it was chosen for, and it is the same collision as institutional override; the law requires a party other than the holder to act.

One more delegate is arriving, and it may make this section the most consequential one in the post. An AI agent acting for a person is exercising delegated authority under exactly the definition above, at a volume and granularity no legal instrument was designed for, and what that does to the demand argument comes later. The relevant point here is that it is the same architectural question, asked by a party that will not accept a paper fallback.

Here is why this belongs beside the lock-in argument rather than in a chapter on accessibility. Binding is one of the four load-bearing choices. It is settled early, by people optimizing for launch, and cannot be revisited once a population depends on it. A program that models the holder as a permanently competent adult has not deferred the lifecycle question. It has answered it, in the negative, and built the answer into the foundation. Adding delegation afterwards means weakening the binding guarantee the architecture was chosen for, and the record contains no example of a deployed identity system successfully doing that. Miss the lifecycle at the start and you are in a corner you cannot reach from inside.

The consequence lands on the acceptance side, not the holder side. Where delegation is legally routine, and in banking and healthcare it is entirely routine, a system that cannot represent it does not replace the paper process but runs alongside it. The verifier keeps the manual channel, keeps the staff who operate it, keeps the training and the audit trail, and now maintains a digital channel as well, so the credential has removed no work.



The assisted channel, which is where these cases actually get solved. A staffed or self-service terminal carries the document reader, the camera and the fingerprint scanner, so the holder needs neither a smartphone nor confidence with one, and a human can stand next to it. Vendors including IDEMIA, Thales and Vision-Box build this category. It is not a free fix: a terminal estate is capital plus floor space plus staff plus a maintenance contract. It is an operating cost, and operating costs are the ones that go unfunded. But a program with no assisted path has not decided to exclude these populations so much as failed to notice it was deciding. US Customs and Border Protection photograph, public domain.

## 10. Eleven Ways an Identity System Fails

You have already met most of these. Part I used no anchor tenant, coordination failure, exclusion, political constraint and slow failure as if they were established terms, and they were not, they were mine, and I used them because narrating nine sections of history without them would have been unreadable, and the debt comes due here.

The claim is not that these eleven words describe the record, which would be unfalsifiable, since they were chosen after reading it. The claim is narrower and testable in three ways. First, that the set is complete enough: every failure in section 11 lands in at least one, and I did not have to invent a twelfth while tagging thirty-two programs. Second, that the modes are separable: a mode that always co-occurs with another is not a mode, it is a symptom, which is why revocation model sits inside lock-

in rather than beside it. Third, and this is the one that earns the taxonomy its place, that the split between structural and execution predicts something. A program in an execution mode can be rescued by competence. A program in a structural mode cannot be rescued by anyone inside it, and five of the eleven are structural.

That third property is why an instrument beats a list of lessons. A list tells you what went wrong, where this tells you whether to keep going.

Two design decisions matter more than the individual entries. Programs carry multiple modes, because they fail in several ways at once and the causal order between them is usually the finding. Verify carries seven. Assigning it a single cause records one symptom and loses the mechanism. And each mode is marked structural or execution, which is the distinction that changes what you do next.

Two places where the set does not hold up as cleanly as the diagram suggests, since a taxonomy that never resisted its own cases is usually one that was fitted to them. Framework-without-enforcement and coordination failure are not properly separable. The 1999 Directive carries both, and on most readings they are the same fact described from either end: nobody could make the national stacks converge, and nothing in the Directive obliged them to. I kept them apart because the remedies differ, since one wants a conformance regime and the other wants a party with authority, and that is a weaker reason than I would like.

The harder case was e-passports. It is the most widely deployed identity credential in history, it is used every day, and it took two decades to start delivering the fraud prevention that justified building it. Tagging it working and letting four failure modes carry the rest is a judgment that could reasonably go the other way, and a different person sorting the same record would produce a different count in the outcome column. That is the status of the numbers in section 11.

They remain analytical rather than empirically derived. They came out of sorting the record, not out of testing against an independent sample, and the falsification is to hand the record to somebody else and compare classifications against mine.

|                                                                                      |                                                                                                                 |            |
|--------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|------------|
| <b>DEMAND SIDE</b><br>The verifier did not, or could not, accept.                    | <b>No anchor tenant</b><br>Credentials issued; no verifier obliged to accept them.                              | STRUCTURAL |
|                                                                                      | <b>Verifier integration cost</b><br>Accepting cost the verifier more than accepting was worth.                  | EXECUTION  |
|                                                                                      | <b>Liability floor</b><br>Non-delegable obligation, so no credential reduces its risk or work.                  | STRUCTURAL |
| <b>COST AND ACCESS</b><br>The wrong party paid, or the holder could not get through. | <b>Cost/benefit misaligned</b><br>The holder or issuer bore the cost; the verifier collected the benefit.       | EXECUTION  |
|                                                                                      | <b>Holder friction</b><br>Using it cost the holder more than what it unlocked was worth.                        | EXECUTION  |
|                                                                                      | <b>Exclusion</b><br>Evidence, device, capacity or delegation requirements denied service.                       | EXECUTION  |
| <b>INSTITUTIONAL</b><br>Nobody could force the convergence the design required.      | <b>Political constraint</b><br>Architecture chosen for acceptability, or the program stopped.                   | STRUCTURAL |
|                                                                                      | <b>Coordination failure</b><br>Many independent parties had to converge; nobody could make them.                | STRUCTURAL |
|                                                                                      | <b>Framework without enforcement</b><br>A specification existed; conformance testing and consequences did not.  | EXECUTION  |
| <b>OVER TIME</b><br>Delivered, then degraded or froze.                               | <b>Governance underfunded</b><br>Security review, supplier management and protocol migration stopped at launch. | EXECUTION  |
|                                                                                      | <b>Locked-in architecture</b><br>Critical mass made an architectural mistake effectively unfixable.             | STRUCTURAL |

Five of the eleven are structural. A program landing in one of those cannot be rescued by working harder, and the options are to change the use case, change the rule, or stop. The other six are real engineering and funding problems.

## 11. The Record

Here is the record the rest of this post rests on. Filter by family, by individual mode, or by whether acceptance was mandated, and watch the distribution move. Solid chips are primary causes; outlined chips are contributing.

### Failure modes by family, across 11 national schemes

One thing about the outcome column before reading it. Working answers a narrow question, which is whether the program reached and sustained the adoption it set out to achieve. It does not mean good, safe, or well governed. Estonia is working and froze 760,000 cards. Aadhaar is working and was constrained by its supreme court. Japan's My Number is working and completed a record-by-record national recheck in December 2023. In every case the failure modes are carried by the tags rather than the outcome, which is why a program can appear as working and still be tagged twice for governance. If that seems like a generous bar, it is the same bar the field applies when it counts its own successes, and applying a stricter one would mostly mean grading these systems against my preferences rather than their objectives.

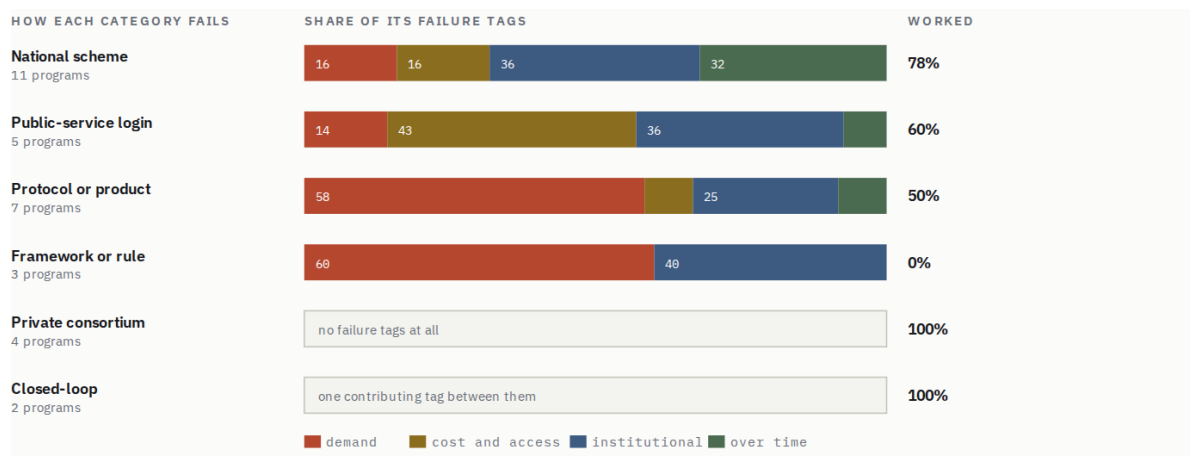
One thing to settle before the counts, because I have said the opposite in public. At the Utah summit and in the draft this post grew out of, I put the failure rate at roughly



seven in ten. That number came from the literature and from the programs everyone already writes about, which is to say from a sample selected for being worth writing about, and building the table below changed it. Of the twenty-eight programs here where I could identify an outcome, nineteen worked.

Both figures come from biased samples pointing opposite ways. Failures generate post-mortems and working systems generate nothing to read, so seven in ten over-counted; the programs I could reconstruct in enough detail to tag are the documented ones, and quiet abandonment leaves no documents, so nineteen probably under-counts. Neither is a base rate. The distribution of modes underneath is the part that carries information.

The table opens on national schemes, because those are the programs this post is mostly about, and every count quoted in the prose below is for the whole record of 32 unless it says otherwise. Use the kind filters, though, because sorting by category turns out to matter more than I expected when I built it.



The rows are not variations on a theme. They are different failure profiles, and the two at the bottom have almost nothing to explain. Small denominators, so treat the percentages as shape rather than measurement.

Read the top three rows against each other, because the contrast is the finding. Protocols and frameworks die on the demand side, at roughly six in ten of their failure tags; no anchor tenant, integration cost nobody would pay. National schemes register far less there, at 16 per cent, and instead fail institutionally and over time, at 36 and 32 per cent.

That looks like it weakens the argument of this post, since the programs the title is about are the ones least troubled by absent demand. It does the reverse, and the mechanism is why: a state can compel acceptance. That is the one thing a national scheme has that a protocol does not, and it means the demand problem is solved by fiat rather than solved on the merits. So national schemes clear the hurdle that kills everything else, and then pay for the way they cleared it; politics, because a mandate is a political act with a political lifespan, and governance over time, because compelled acceptance produces a live system whose operating bill nobody costed. That is Japan's



7,312 mismatched records exactly, and Article 45 in prospect. The demand problem does not disappear when you mandate your way past it, only deferred and repriced.

The bottom two rows are the other half of the same point, and they are why the comfort should be limited. Private consortium and closed-loop programs carry essentially no failure tags between them and worked in every case. Four and two programs respectively, so this is an observation and not a result. But they are the categories where the party carrying the verification obligation built the system, which means they never had a demand problem to solve or to mandate around, and they are the only categories in this record with nothing much to explain.

Four things in that distribution stand out.

No failure here was cryptographic. In this sample, I did not identify weak cryptography as the primary cause of any failed outcome. This is the thesis of the conventional wisdom, and the record is consistent with it, with the caveat any sample carries: a set of documented programs cannot prove a negative. The technical layer is the layer this field is best at.

Across the whole record the demand-side family dominates. No anchor tenant is the single most common mode at nine appearances, and coordination failure sits behind it at eight. Note what the category split above does to this; the aggregate is driven by protocols and frameworks, and it is much weaker among the national schemes the table opens on. Together they say the same thing. The credential existed and the acceptance side did not.

Failures average several modes each. Assigning one cause per program would change the conclusions, and not for the better. A single-cause reading of Verify blames onboarding UX, which is the last link in a chain that starts with a political constraint. Fixing the UX would not have saved it.

Successful programs become exposed to temporal failure modes even when none has yet been observed. Estonia, Aadhaar, OAuth and mDLs already carry one; BankID, Singpass and passkeys do not, yet. Success is not an exit from the record; it is a move to a different family. Part III is about that.

The three entries marked in flight are deliberate. eIDAS 2.0, Utah's SB260 and the MOSIP deployments have not reached an outcome, and sorting a live program into its expected failure would be forecasting dressed as evidence. It would also be unfalsifiable, since the forecaster would be the one grading the forecast. Their exposure is set out later, as a prediction. One further entry, Entra Verified ID, is marked uncertain rather than failed: an active product with continuing investment, but without public adoption data sufficient to classify the outcome either way, so it sits outside the denominator.

The sample is survivorship-biased. It over-represents national programs in wealthy countries with a free press and an active public accounts committee. The quiet municipal failures, the corporate pilots that ended in a slide deck, and programs in jurisdictions that do not publish are all missing, and they are plausibly the majority. The direction of that bias is not obvious, since small failures are if anything likelier to be no-anchor-tenant failures, which would strengthen the largest column rather than weaken it. But the counts here are a floor on the pattern, not a measurement of it.

## 12. Issuance Is Scored. Acceptance Decides.

Now the chain the distribution supports.

The demand-side family is the largest because “they forgot about verifiers” is not a satisfying explanation for thirty years of intelligent, well-resourced institutions making the same choice. They were all responding to the same structure.

An issuing authority controls enrollment, credential lifecycle, revocation, the technology stack beneath them. It can plan that work, budget it, staff it and report on it. It can tell a minister or a board, on a specific date, how many credentials exist. Acceptance is not like that. It sits with banks, agencies, retailers and employers who have their own budgets, their own regulators, their own integration backlogs and no obligation to help. It cannot be planned by the issuer and cannot be reported as progress until it has already happened.

So the program manager who optimises for what is measurable and deliverable is behaving rationally, and produces the failure anyway. The deliverable and the outcome belong to different parties, and only one of them is in the program plan.

If acceptance is the problem, mandate it. States can, and the record shows they do, and it works well enough that the demand-side family barely registers among national schemes at all.

The record also shows what it costs, and two programs make the point better together than either does alone. Germany forced issuance without forcing acceptance. Automatic activation from 2017 put the eID on more than 97 per cent of cards, and use moved from just under ten per cent to 22 per cent over the following years. Coverage solved, acceptance untouched, because a default changes what people hold and not what anybody will take. Japan forced both, with cash incentives and by folding the health insurance card into the credential, and got compliance. What compliance then surfaced was 7,312 insurance records linked to the wrong individual, a prime-ministerial emergency review and a record-by-record national recheck, completed in December 2023.

But two mandates is not the set, and taking only these two would make compulsion look worse than the record says it is. Denmark mandated too, and it worked. The

difference is what got mandated. Germany and Japan compelled the credential: hold this, activate this, register this. Denmark compelled a transaction, requiring citizens to receive public-sector post digitally, and left the credential as the way to do the thing you now had to do. PIV and CAC did the same in a narrower setting, mandating access to a building and a network rather than possession of a card. In each case the mandate attached to something the person needed to accomplish and the mandating party bore the consequences of getting it wrong.

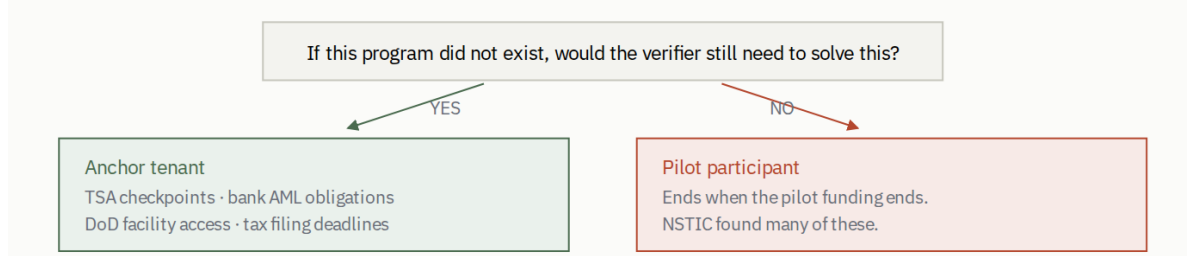
So mandates have a place, and it is a specific one. A mandate can substitute for the demand a program cannot generate, but only where the compelled thing is a transaction rather than a credential, the compelling institution is also the one that has to make it work, and the operating model was designed on the assumption that everyone would arrive at once. Denmark planned for a mandate. Japan mandated and then discovered what the mandate had committed it to. Both are compulsion; only one of them was designed.

Two mandates, two different bills, and neither of them is the bill a voluntary program pays. Germany bought a number that does not mean what it appears to mean. Japan bought real acceptance and discovered that the operating model underneath it had never been tested, because ten per cent usage had been concealing the data quality the whole time. So compulsion is not an exception to the argument in this section. It is a way of paying for the missing half later, in political exposure and in operating cost, and Europe is trying it at continental scale.

*Nobody decided that verifier adoption did not matter. It simply was not anybody's deliverable, and things that are not anybody's deliverable do not get done.*

That reframes it from a best practice into something closer to a definition. An anchor tenant is a verifier that arrived with an independent reason to verify, one that existed before your program and would exist without it, rather than simply a large customer. TSA needed to check identity at a checkpoint whether or not mDLs existed. Scandinavian banks had regulatory identity obligations and direct fraud exposure. The Department of Defense needed to control access to facilities. In each case the identity system did not create the demand. It attached itself to demand that was already there and already funded.

#### THE ANCHOR TENANT TEST



The distinction is not size or enthusiasm. It is whether the verifier's motive is exogenous to your program. A large, enthusiastic participant whose only reason to verify is that you asked is still a pilot participant.

No verifier commits to a credential that does not exist yet, so demanding one first is demanding the ecosystem before the ecosystem. The TSA did not sign up for mobile driving licenses in advance of the standard. Apple and Google shipped wallets, states issued, and acceptance followed. On a strict reading the test would have killed the clearest success in the modern record.

The objection lands on the word named and not on the test. What has to exist beforehand is the motive, not the signature. Airport identity checking is an obligation that predates mDLs by decades and would exist if they had never been invented, which is why acceptance was available to be won. Compare NSTIC, which could not answer the same question about any of its pilots. The thing you need on day one is not a commitment but an answer to which existing obligation this makes cheaper to discharge, and for whom. That answer is available at the whiteboard.

The harder case is passkeys, and it is harder because it looks like a counterexample. No verifier committed to them in advance, and there was no anchor tenant in the ordinary sense at all. What there was instead is a standing, expensive, universally understood problem, distributed across every verifier on the web, in password databases, credential stuffing and recovery tickets. The motive pre-existed so widely that nobody needed to name a holder of it. So the test survives, by a route that shows named is doing the wrong work. What counts is pre-existing motive, whether concentrated in one institution or spread across all of them. What does not count is motive your program has to create.

Which raises the question this post has so far avoided. Suppose you look and there is no pre-existing motive to attach to. What can actually be done? The record supports five moves.

Attach to an obligation somebody already has. The only one with a clean record, which is why the anchor tenant test comes before anything else. Be the verifier yourself. Also clean, and structurally the strongest of all, because it removes the boundary rather than crossing it. This is the Nordic and defense answer, and it explains those outcomes better than culture does. Pay for acceptance. Subsidise the integration, or pay per transaction. Verify tried a version of this and it failed, not because the idea is wrong but because per-verification payments at volumes that never arrive are a subsidy in name only. If you buy acceptance, buy it in a form that survives low volume. Indemnify the verifier. Attractive and mostly unavailable, because section 13 is about the rule that stops you. Where liability can be contractually reallocated this is powerful; where it is non-delegable, no indemnity you write reaches it. Mandate it. Works when the party imposing the mandate also carries the consequences, which is why PIV and CAC hold and why section 20 is sceptical of Article 45.

Nothing on that list involves improving the credential. Every available lever is economic, institutional or legal. If your answer to weak verifier demand is a better protocol, you do not have an answer.

**KEY LESSON**

An identity program cannot manufacture verifier demand; it can only attach to demand that already exists. The question to ask before architecture, funding or standards selection is which pre-existing obligation this system makes cheaper to discharge, and for whom.

## 13. The Liability Floor

Section 7 met this constraint in the field. Here is the general form, because it is the hardest boundary in the post and the one most often mistaken for a temporary difficulty.

Call it the liability floor: the level below which a verifier's responsibility cannot be delegated, whatever the credential says or how well it says it. Above that floor a credential can genuinely remove work. At it, the verifier must still perform and stand behind its own determination, so the credential becomes at best an input that makes the verifier's own process marginally faster, competing on cost against whatever it does today.

There is a second floor underneath the legal one and it holds even where the law is permissive. A liability transfer is only real if the party receiving it can absorb the loss and is paid enough to want to. Neither is usually true. Identity providers are asked to stand behind determinations whose downside is a bank's fraud loss or a benefits agency's exposure, on fees priced per verification in cents, with a balance sheet nowhere near the risk. So the transfer gets written down and then capped, and the cap is set at a level the provider can survive rather than a level that matches the harm, which means the harm stays with the verifier and the paperwork says otherwise. Anyone who has read a certificate authority's warranty against the value of what depends on that certificate has seen the arithmetic.

Which recasts the regulatory rule as something other than obstruction. Non-delegable liability is a legislature declining to let institutions pretend a transfer happened when the economics never supported one. The rule is upstream of the incentive problem rather than separate from it, and a proposal that argues the law should permit delegation still has to answer the question the law is standing in for: who is going to carry this, can they, and what are they being paid.

## THE VERIFIER'S TOTAL OBLIGATION, AND HOW MUCH OF IT A CREDENTIAL CAN REMOVE

## Above the floor, as in a hiring check or a membership

|                             |          |                                                    |
|-----------------------------|----------|----------------------------------------------------|
| Work the credential removes | Retained | The pitch works, and cost and risk genuinely fall. |
|-----------------------------|----------|----------------------------------------------------|

## Near the floor, as in AML/KYC onboarding or benefits disbursement

|      |                                                                                                |                                                                                                                            |
|------|------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Some | Retained. The institution must still perform, evidence and stand behind its own determination. | The credential can remove the checking; the responsibility stays, so the value the pitch assumes is capped, not delivered. |
|------|------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|

## This is a difference in kind, not in degree.

Most regulation makes a design more expensive and remains satisfiable. Residual responsibility does not raise the price of the value proposition; it caps it. A business case that assumes the floor will move is betting on legislators rather than on engineering.

The corollary is that the transactions where holder-controlled credentials add the most conceptual value are the transactions where the floor sits highest.

The question to put to any proposal is how much of the verifier's obligation the applicable rules permit it to stop performing, and the answer is frequently much less than the pitch assumes.

The floor is set by regulation and can therefore move, and in places it has. Reliance frameworks in some European anti-money-laundering regimes permit limited delegation under conditions. But it moves through legislatures on their timescale, not through standards bodies on yours.

This is not just saying regulation is hard. Most regulatory constraints are compliance costs, expensive and annoying, and satisfiable. The liability floor works differently. Certified digital verification can remove the identity-verification component of customer due diligence, but it does not remove the institution's responsibility for the overall determination, so the economic question is how much duplicated work the applicable rules and the institution's risk model permit it to stop doing. Residual responsibility sets the value ceiling, and you cannot comply your way above it.

Section 1's point about the word trust lands here with some force. To accept another party's verification is, in the engineering sense, to become trusted-by-proxy; their failure can now break your security policy. The liability floor is the legal system declining to let an institution obscure that with vocabulary. That is regulators understanding exactly what delegation means and refusing to let the word trusted do the work of an indemnity.

*Where responsibility for the determination stays put, a credential can move the checking but not the accountability. Every business case that assumes the accountability moves too is a proposal to change the law with a protocol.*

There is an uncomfortable corollary for the decentralised identity movement, and it does not need hedging. The use cases where holder-controlled credentials add the most conceptual value, the high-stakes and high-consequence identity-critical transactions, are exactly the use cases where the residual responsibility is largest. The technology promises most, in principle, in the places where the least of the obligation is available for it to remove.

Let me put the institutional version plainly, because the polite version has let this proposal recur for a decade without its economics ever being stated. A universal identity wallet for regulated financial onboarding can, under current rules, discharge the identity-verification component of the bank's obligation and nothing else; the bank still owns the customer-risk assessment, the enhanced diligence, the purpose-and-nature judgment and the records. So the wallet's value is capped at that component, and no improvement in selective disclosure, revocation, binding, or assurance level raises the cap, because none of those things touches the rules that keep the rest of the obligation with the bank. Raising the cap is a legislative project, not an engineering one. Pilots that assumed otherwise produced a bank doing its full diligence alongside a credential it was also checking, which is more work rather than less, and they ended when the funding did.

None of that means the floor cannot move. It is regulatory, so a legislature or a supervisory authority can lower it, and a few European reliance frameworks have moved it a little. But anybody proposing this use case should be able to name the statute they intend to change, the body that would have to change it, and roughly when. A proposal that cannot answer those three questions is not an early-stage product. It is a request that the law be different, filed in the wrong department.

## 14. Where Decentralisation Actually Works

The liability floor draws a boundary, and a boundary has two sides. Being specific about the side where decentralised models work is more useful than another round of argument about whether they work in general.

They work well for moderate-stakes professional credentials such as diplomas and professional licenses, where fraud risk is manageable, verification today is genuinely painful, and selective disclosure adds privacy value the holder can feel. They work for voluntary consumer contexts such as age verification and membership, where convenience dominates and platform wallets have already solved distribution. And they work in cross-jurisdictional scenarios where no single central authority exists or would be trusted by all parties, which is the case bridges were invented for and never solved well.

Centralised or federated models tend to win in high-stakes financial services, where the liability floor sits at the institution and audit trails are a regulatory artefact rather than a design preference. They win in government benefits, where fraud accountability is political and agencies need direct control. And they win wherever an institutional override is legally required.

That last condition is usually left out of the argument and is not a footnote. Some systems must be able to revoke, freeze or override a credential unilaterally and immediately, in response to a court order, a sanctions listing, a safeguarding intervention or a compromised population. Decentralisation limits exactly that



capability, by design and on purpose. This is not a bug to be engineered around; it is the property the architecture was chosen for. A use case carrying a legal override requirement is one where the architecture and the requirement are in direct opposition, and one of them has to give.

Delegated authority is the same collision and gets even less attention. A guardian, an attorney under a power of attorney, a court-appointed deputy, a parent acting for a child, an executor acting for an estate; each is an ordinary legal instrument requiring a credential to be exercised by somebody who is not its subject. Holder binding forbids that, and holder binding is what the architecture was chosen for. It lands on the verifier rather than the holder, and the architectural test is the same one as override. If the law routinely requires a third party to act, an architecture whose central guarantee is that no third party can act is not immature in that context. It is the wrong instrument, and adding a delegation feature to it means weakening the guarantee it was selected for.

Two further considerations belong in the same assessment. Decentralised systems ask holders to manage keys and recovery, which is fine for sophisticated users and produces exclusion for everyone else. And exclusion in an identity system is not a degraded experience, it is a denial of the service the credential gates. And a great many people actively prefer institutional account recovery to self-custody, which the sovereignty framing tends to treat as false consciousness rather than as a reasonable preference about where to put risk.

| HOLDER-CONTROLLED WORKS                                                                                                                                                                                                                                                                                                                                                                      | CENTRALISED OR FEDERATED WINS                                                                                                                                                                                                                                                                                                            |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>Moderate-stakes professional credentials</b><br/>Diplomas, certifications, licenses. Verification today is painful; selective disclosure adds privacy the holder can feel.</p> <p><b>Voluntary consumer contexts</b><br/>Age, membership, loyalty. Convenience dominates and platform wallets have already solved distribution.</p> <p><b>Genuinely cross-jurisdictional cases</b></p> | <p><b>High-stakes financial services</b><br/>The liability floor sits at the institution and audit trails are a regulatory artefact, not a design preference.</p> <p><b>Government benefits</b><br/>Fraud accountability is political; the agency needs direct control.</p> <p><b>Anywhere an institutional override is required</b></p> |
| <p><b>DISQUALIFYING, NOT MERELY DIFFICULT</b><br/>A legally required unilateral override, whether a court order, a sanctions listing, a safeguarding intervention or a compromised population. Decentralisation limits exactly that capability by design and on purpose. This is the property the architecture was chosen for, not a gap in its roadmap.</p>                                 |                                                                                                                                                                                                                                                                                                                                          |
| <p>Two further constraints belong in the same assessment. Key and recovery management excludes unsophisticated holders, and many people reasonably prefer institutional recovery to self-custody.</p>                                                                                                                                                                                        |                                                                                                                                                                                                                                                                                                                                          |

Match architecture to the liability and override requirements before matching it to principles. A design that cannot support a mandated override is disqualified from that context, not merely unfinished in it.

**PART III**

# Over Time

## 15. The Failure That Doesn't Look Like One

Everything so far has been about programs that did not achieve adoption. This part is about the ones that did, because achieving adoption moves a program into a different failure family rather than out of the record.

A slow failure is a system that reaches deployment and operational status and then fails to deliver its long-term value proposition, because investment in governance and evolution stopped at launch. It does not collapse, which is precisely what makes it durable. It keeps working well enough to justify its continued operation and never well enough to deliver what it promised, and the gap between those two states is where most of the value quietly goes.

The e-passport is the clearest case available. Electronic passports have been issued under ICAO Doc 9303 for about two decades by more than 150 countries. By any deployment measure this is the most successful identity program in history. Yet interoperability persistently lagged the specification, because chip implementations, key management and validation protocols varied, and the common workaround was to relax certificate checking, which is to say to disable the security the deployment existed to provide. The security record accumulated in parallel. Clandestine scanning through unique chip identifiers, and skimming and cloning where chip binding was absent, eavesdropping demonstrated at range, biometric leakage, and low-entropy keys crackable in hours. Reader and validation estates told the same story, lagging mass issuance by years, with public key directory participation and full passive authentication arriving long after the chips they were meant to check.

The part that gets left out of that account, and that changes what the case is evidence of, is that it did eventually get fixed. Directory participation broadened, validation infrastructure was built, gates went in, and the checking that was skipped in the early years is now routine at a great many borders. The interoperability arrived. It arrived roughly two decades after mass issuance, which is the whole point rather than a mitigating detail. Nothing forced the sequence to run in that order. Chips were issued to hundreds of millions of people first, and the agreements and infrastructure that made the chips worth reading were assembled afterwards, against the resistance of an installed base that already worked well enough for the officer at the desk.

So this is not a system that failed. It is a system that spent twenty years not delivering what it was funded to deliver, arrived eventually, and never had a year in which anyone had to account for the gap. That is a more uncomfortable finding than failure would be, and it is exactly the prediction section 20 makes about Europe: retrofitted

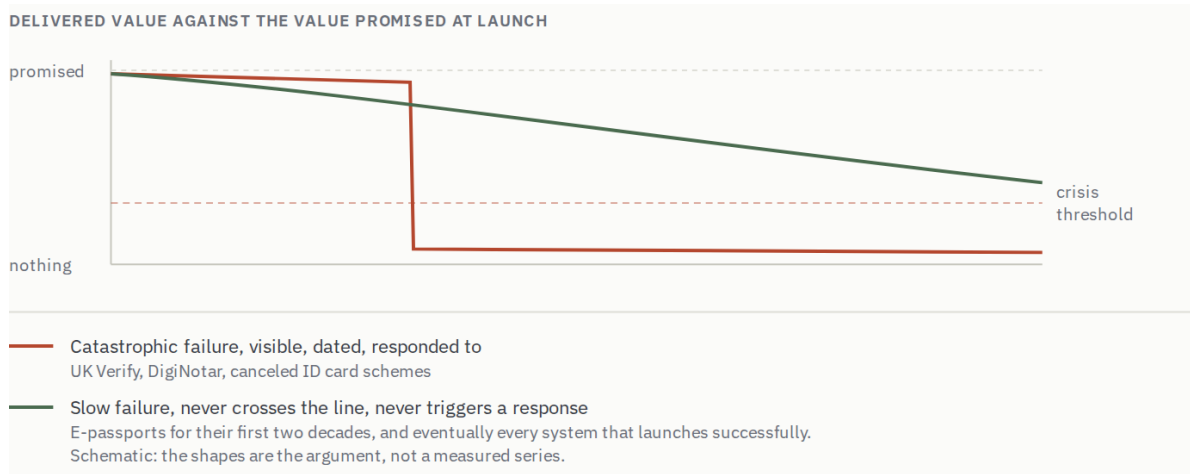
interoperability is not impossible, it is expensive and slow and it happens on nobody's watch.



The acceptance side, made physical. Everything else in this post is about verifiers as an abstraction; this is what one actually looks like. The chips were issued to hundreds of millions of people across more than 150 countries, and whether any of it worked came down to how many of these existed, whether they checked the full certificate chain, and whether anyone funded their upkeep. They were built eventually. The gap between issuing the chips and being able to read them properly ran to about two decades. UK Border Agency photograph, Open Government License v1.0.

Nobody would describe the e-passport program as a failure. It is deployed, it is used, and the checking it depends on now largely happens. It took about twenty years to get there, and for most of those years it was not delivering the fraud prevention that justified building it.

Estonia's 2017 vulnerability affected roughly 760,000 cards and forced a national freeze. One Login was struck from the DIATF register in 2025 through a supplier's lapse and needed nine months to get back on. Both delivered competently and were undone by the part that runs afterwards, though not by the same thing: Estonia had never planned for the credential failing at population scale, and nobody at GDS was checking whether a supplier's certification was still current.



A catastrophic failure gets a post-mortem, a parliamentary committee and a replacement program. A slow failure gets a renewed maintenance contract. The second is more common and, summed across the record, considerably more expensive.

This is the same shape as an argument I have made elsewhere about assurance. A conclusion reached at a point in time keeps its authoritative form while the system

underneath it moves, and nothing in the document changes to reflect that. Identity has the same structure on a longer clock. A credential scheme certified at launch retains its certification, its documentation and its political standing long after the threat model it was designed against has moved. The assurance model and why continuous assurance did not happen work through why that gap persists; identity is one of the domains where the cost of not closing it is most visible.

## 16. Governance Is an Operating Cost

If slow failure is the default, the counter has to be a budget line rather than an intention. So here is a number: 10 to 15 per cent of initial development cost, annually, in perpetuity, for continuous security review, supplier management, protocol evolution, conformance testing and compliance.

The figure is a planning heuristic drawn from what the programs in this record spent, or conspicuously failed to spend, and not a measured result. It ought to be established properly by someone with access to a set of program budgets, and it should be contested with better data rather than repeated. The objection that a soft number invites attack on the number rather than the claim gets it backwards; a capability list is what gets nodded at and deferred, while a percentage has to be argued down line by line, and being argued down is the point.

There is now an anchor for it inside this record. One Login's certification lapse happened because nobody was continuously verifying a supplier's compliance status, which is a modest standing function costing roughly what a small team costs. Recovering from it took nine months. That is the trade the heuristic describes, and a real program has now paid it: a standing function costing roughly what a small team costs, against most of a year off the register.

What the money buys, in rough order of how often it is omitted.

Protocol and cryptographic evolution. Algorithms weaken on a published schedule. The post-quantum migration is the live example. NIST released FIPS 203 through 205 in 2024, and harvest-now-decrypt-later means the clock for long-lived credentials started before the machines exist. Migrating a deployed identity system through a signature-algorithm change is exactly the sustained, unglamorous work that e-passports demonstrate does not happen by itself.

Rehearsing failure at population scale. Estonia is the case, and it is the one people get wrong because the program is a success. Identity was embedded in tax, voting, prescriptions and business registration from the start, which is why it worked. What was not designed was what happens when the credential itself fails for everybody at once. In 2011 roughly 120,000 cards went out faulty; in 2017 a chip vulnerability affected around 760,000 and the state froze the certificates. Estonia handled both, competently, and improvised while doing it, because mass revocation and re-issuance

had never been treated as a normal operating condition with a budget and a rehearsal behind it. A program that cannot say how it would suspend and re-credential its whole population in a fortnight has not yet costed its operating model, however well the launch went.

Supplier management. One Login's certification lapse came through a supplier, which is the ordinary case rather than an unlucky one. Compliance obligations belong in contracts with consequences attached, and continuing compliance has to be verified rather than assumed at renewal.

Threat model refresh. The systems in this record were designed against static threat models and are now meeting adversaries that did not exist at design time. Synthetic media is the current instance. The circulating percentages are not worth quoting. The best of them come from identity-verification vendors with an interest in the number being large, and the rest have no traceable provenance, and because the numbers are not the interesting part.

The interesting part is that liveness detection is a detection race, and detection races have an asymmetry that does not favor the defender. The attacker iterates continuously; the defender iterates on a procurement cycle. A liveness capability bought once and never revisited will be defeated on the vendor's release schedule rather than on yours, and every generation of detector trains the next generation of generator. You can win rounds. The house is not the one buying the detector.

Which suggests changing the question from detection to provenance. Not does this video look real, a judgment about pixels that gets harder every quarter, but what produced it: this application, on this device, in this attested state, captured this frame at this moment. Device attestation is the closest available approximation to knowing where a capture came from. It is a different kind of claim from a detector's and it fails differently; defeating it means compromising a hardware-backed attestation chain rather than out-running a classifier.

The platforms are not equivalent here. Apple's model does not permit an administrator to override the properties attestation rests on, so an assertion about which application captured what retains meaning under a hostile owner. Android's hardware-backed attestation is likewise designed to let an off-device verifier check a chain rooted in hardware, and the difference is in what an owner can do to a device they control rather than in the strength of the attestation itself. Neither is impossible to defeat, the difference is cost rather than kind, and a verifier relying on capture provenance should price the difference between a device estate it controls and one it does not.

None of which makes the device claim mean what it is usually taken to mean, and this is the more common failure. A device-bound credential is presented as a one-to-one binding between a person and a key, and it is not one. Devices are shared. Phones get handed to children. My own children have enrolled their fingerprints on their mother's phone without asking, which took them under a minute and no special knowledge, and

every family has some version of that story. What the device can honestly assert is that this credential was presented from this device in this state. That the subject presented it is an inference laid on top, and it is a good inference in most cases and a silent one in the rest.

Device binding is still the strongest widely deployed thing we have. The failures come from misreading what was assumed, and from not noticing who ends up carrying the consequence when the assumption is wrong.

The Social Security number is the ninety-year-old version, and section 1 has already put it on the table without saying what it demonstrates. It was created in 1936 to track earnings under one federal program. It became the identifier the United States uses for credit, employment, tax, insurance, health records and account recovery, because it was the only number everybody already had, and it was then used not only to say who someone is but to prove it, which is a different job that a number printed on a card and disclosed to hundreds of institutions cannot do.

The Social Security Administration saw it happening and objected in the plainest way available. From 1946 to 1972 the cards were printed with the legend FOR SOCIAL SECURITY PURPOSES, NOT FOR IDENTIFICATION. It made no difference. The number was useful, no alternative existed, and the agency had no way to stop anyone from relying on it. The legend was eventually dropped because it was being ignored, which is the clearest statement in this record that an issuer's stated scope does not bind the parties who find the thing convenient.

What that produced is exactly the two failures the pattern predicts. Every database keyed on the same number can be joined to every other, so a linkage nobody designed became available to anyone who accumulated enough records. And a shared identifier used as a secret is a credential with no revocation, which is why identity theft in the United States has a shape it does not have in countries where the identifier and the authenticator are different objects.

SMS one-time passwords are the same story eighty years later, and this time everybody now knows the ending nobody predicted. One-time passwords were pressed into service as a second factor because hardware tokens cost something like ten times as much per user to deploy and had to be physically issued to each one, while the message carrier was already in everyone's pocket and cost nothing to reach. But the phone network was never designed to keep a short numeric string confidential for authentication purposes. Intermediaries in the delivery path can see the values, number portability was built to be easy for the customer's benefit, and SIM swap turned out to be a social engineering problem rather than a technical one. The carriers had not agreed to underwrite anyone's authentication, were not paid to, and had no way to know how much was resting on a message class designed for informal text. The property was borrowed, the assumption was never written down, and the consequence

landed on banks and their customers rather than on the party whose design was being relied upon.

That is a general shape, and it is the same one running under the device claim. A mechanism gets adopted for a property it was not built to provide, because it is available and the properly designed alternative is not. Nobody records what is now depending on it. The party whose behavior the assumption rests on is not the party who chose to rely on it and frequently does not know they have been enlisted. Ask, of any deployed system, which of its security properties are load-bearing by design and which are load-bearing by accident, and be clear about who is on the hook when the second kind gives way.

There is an uncomfortable symmetry with section 4. The property making attestation useful is exactly the platform control that section objects to. An iPhone's attestation means something because its owner cannot override it, meaning the owner does not fully control the device. That does not resolve cleanly, and anyone who tells you it does is selling one side of it.

Follow that chain one more step, because it ends somewhere this post has not been. Real-time synthetic video keeps improving, and tools already in circulation defeat most deployed liveness checks, so liveness alone is no longer a basis for believing anything about a remote capture. Attestation is what is left, and attestation can establish that a credential was presented from a particular device in a particular state; it cannot establish by itself that the credential's subject was the person operating the device. So for the transactions where being wrong is most expensive, verifiers keep reaching for the one setting that closes that gap, a device they control with a person standing at it, which is a kiosk or a staffed counter.

Then ask where the kiosk goes. For health and social services the answer has to be within reach of the people being served, and in a dense city that is a solvable problem. Across a country with a dispersed rural population it is expensive. Across the world it is not a plan. Nobody is putting an attested terminal within reach of everyone, and any scheme whose assurance depends on doing so has quietly restricted itself to the places where terminals are economic.

What that forces is not a better global system but the abandonment of the idea of one. Different populations will be reachable at different assurance levels through different channels, and a verifier in one country will have to accept evidence produced under arrangements it did not design and cannot inspect. That is federation, arrived at by elimination rather than preference, and it is the reason the next section matters more than its subject usually suggests. Federation across a spectrum of assurance is a standards problem, and standards are the thing this record shows converging least reliably.



Coordination institutions. Trust frameworks, test suites and certification programs need durable funding. NSTIC's intermediaries faded partly because nobody funded them past the pilot phase.



Both profiles are defensible in a business case and only one of them is a functioning system in year six. The shape of the tail is the decision, and it is usually made by omission.

## 17. Standards Do Not Converge By Themselves

Which is where the previous section leaves us. If assurance has to be federated because no one system can reach everybody, then everything depends on whether a specification written in one place produces something a verifier in another can actually process. That is the item on the operating-cost list large enough to be its own argument, and the record on it is poor.

Conformance and interoperability testing. These are not the same activity. Conformance asks whether an implementation matches the specification; interoperability asks whether two implementations actually work together, and the second keeps failing where the first passes.

The historical analogy settles an argument that otherwise recurs indefinitely. Nineteenth-century American railroads ran on incompatible track gauges, and the problem was not solved by better railcars or more sophisticated couplings. Federal policy picked a gauge for the Pacific railroad, and the large Southern conversion of 1886 was organised by the interconnected operators themselves once the cost of staying incompatible exceeded the cost of moving. Neither route was a consortium agreeing that standardization would be nice. One was a mandate and the other was a bill that had grown too large to keep paying, which is the same forcing function arriving from two directions.

One design rule follows from all of this and costs nothing at the time it matters. Write specifications for clarity rather than for flexibility. Flexibility in a specification is usually a diplomatic achievement, the wording that let everyone sign, and it is paid for later by every implementer who reads it differently. Where a specification permits two readings, deployments will contain both, and the dominant implementation's reading

becomes the real standard regardless of what the document says. That is how OAuth fragmented without anyone deciding to fragment it, and it is the mechanism eIDAS 2.0 is exposed to.

Which sets up the failure this field walks into most reliably, and the one every engineer already knows by reference. Confronted with a fragmented landscape, the natural move is to write the standard that unifies it. Absent a forcing function, that move does not reduce the count but increments it. The incumbents keep operating, because nothing has made them stop, and the unifying standard takes its place beside them as one more thing to support. This is the argument of xkcd 927, the most-cited comic in this industry because it correctly describes the default.

#### NO FORCING FUNCTION



#### WITH ONE



The third box is the whole difference. Nothing about the quality of the specification appears anywhere in either row. Track gauges took the lower path. The 1999 Directive took the upper one.

Both rows begin identically and the unifying specification can be excellent in either. What separates them is whether some party bears a cost for staying put, which is a question about power, not about design. The upper row is Randall Munroe's observation in xkcd 927, redrawn here as a sequence so the lower row has something to contrast with; the comic itself is his and is not reproduced.

So the question to put to anyone proposing a standard, before any technical review, is which existing thing stops being used, by what mechanism, and roughly when. Acceptable answers are a mandate with consequences, a buyer large enough that refusal costs more than conversion, or a platform that ships the new thing by default to everyone. An unacceptable answer, and by far the most common one, is that the new design is better. This record is largely a list of better designs that became options rather than replacements. The 1999 Directive was one more way to sign. GIDS was one more card edge next to PIV. Verifiable credentials are, so far, one more way to assert an attribute alongside SAML, OIDC and X.509, and whether they become the replacement or the increment is not going to be settled by the data model.

It is worth giving eIDAS 2.0 its due here, because it has the strongest answer of anything in the current generation; a mutual recognition obligation is a genuine forcing function, and it is exactly the thing the 1999 Directive lacked. The open question in section 20 is whether an obligation to recognize, without a conformance regime that determines what recognizing means in practice, forces convergence or merely relocates the divergence into twenty-seven compliant implementations.

## 18. The Lock-In Paradox

There is a second temporal failure mode, and it is the more troubling of the two because it is caused by success rather than by neglect.

Once an identity system reaches critical mass, its architectural mistakes become effectively unfixable. The properties that make a system worth having are the same properties that make changing its foundations infeasible. Ubiquity, an installed base of verifiers, a population that depends on it, downstream systems built against its assumptions. Which produces the paradox. The systems whose architecture matters most are precisely the systems whose architecture can no longer be revised.

E-passports are the standing example. Identifier formats, validation models and chip characteristics settled two decades ago, across more than 150 sovereign issuers and a reader estate nobody controls. There is no mechanism by which those choices get revisited, and the post-quantum migration will meet that fact directly. The cryptographic problem is tractable and the coordination problem is the same one that left signature checking relaxed for twenty years. OAuth carries a milder version, where dominant implementations' behavior became the specification and cannot now be corrected without breaking the deployments that constitute the standard. Aadhaar's identifier design and Estonia's card-based model carry their own.

*An identity system's foundational choices have a decision window measured in a few years and a consequence horizon measured in decades. Nothing in how these programs are governed reflects that ratio.*

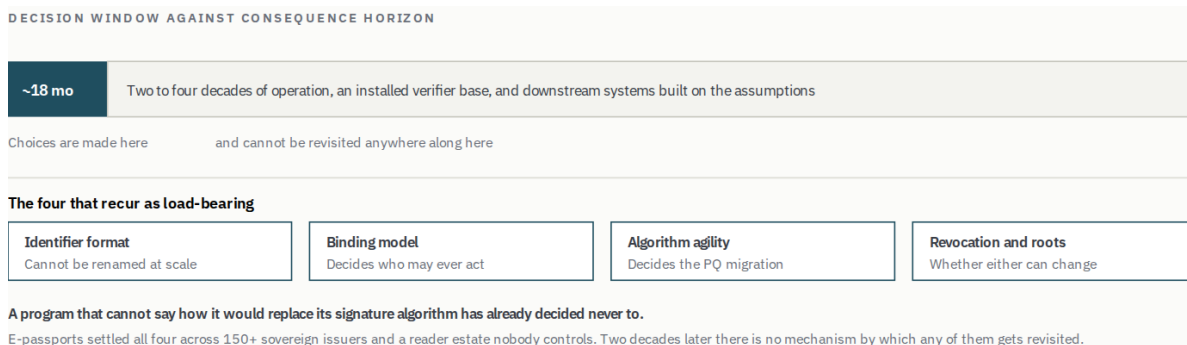
The practical implication is narrow and demanding. Since the lock-in cannot be undone, the only available intervention is at design time, and it consists of identifying which choices are load-bearing before they set. Identifier format, revocation model, signature algorithm agility, and the binding model are the four that recur, with the trust-anchor update mechanism close behind. A program that cannot say how it would replace its signature algorithm has already decided never to, whether or not anyone in the room noticed.

The binding model is the one most often mistaken for a detail, and section 9 is what it costs. Deciding that a credential is bound to one competent adult holding one device is a decision about two things at once, and the second is usually invisible. It fixes what the system can represent, and it fixes what the system is quietly assuming about who is holding the device, which section 16 argues is a weaker assumption than it looks. On the first, it is a decision that the system will never represent a parent acting for a child, an adult child acting for a parent, or any of the ordinary legal instruments by which authority over a person's affairs moves during a normal life. Made at the whiteboard it is one line. Discovered in year six it is unreachable, because the guarantee you would have to weaken is the one the architecture was selected for.

Two practical corollaries follow, and both are about designing for the world rather than for the design. The first is that a government program unable to show meaningful value inside a single electoral cycle, call it two to four years, is exposed to cancellation on a change of administration regardless of how sound it is. That argues for front-loading something visible, not for building worse systems, because a program killed at year five has made the same four load-bearing choices as one that survives, and has left them behind for whoever comes next.

The second is that the ecosystem never fully migrates. There is no identity program in this record that retired the channel it replaced. Paper persists, counters persist, the phone line persists, and they must; delegation, assisted enrollment and the populations the flow was not designed for all live in the old channel. So hybrid operation is not a transition state to be endured until cutover. It is the permanent condition, it has a permanent cost, and a business case that shows the legacy channel switching off in year three is describing something that has never once happened.

This is the same structure as the calcification argument in the WebPKI, where a trust ecosystem's ability to change is bounded by the least agile participant, and it is why the post-quantum transition is a governance problem before it is a cryptographic one.



The ratio between the two bars is the problem, and nothing in how these programs are governed reflects it. Lock-in is caused by success, which is why it is never on the risk register.

### KEY LESSON

Success removes options. The choices that will still be constraining in twenty years are made in the first eighteen months, usually by people optimizing for launch, and the only defense is naming them explicitly while they are still choices.

**PART IV**

# Applying It

## 19. Reading a Proposal

The most useful thing this record produces is a diagnostic for people reading proposals to build them, meaning ministers, investment committees, procurement officers, standards participants, and the architects who have to decide whether the thing in front of them is sound.

Twenty questions. Answer them about a real proposal and the pattern of answers names the modes it is heading for, while there is still time to change them.

### **Program diagnostic**

Twenty questions mapped to the eleven failure modes in section 10. They are written to be answered about a real proposal, on paper or in a meeting, and are printed here in full for that reason. If your browser runs the scoring, answering all fifteen names the modes the proposal is exposed to and separates the structural ones from the fixable ones. Nothing is stored or sent anywhere.

A word on why the opening singled out two of these twenty. They are not the most important questions, they are the two with the best ratio of diagnostic power to effort, and they work in opposite directions. The anchor tenant question is structural, so a bad answer is close to fatal and no delivery plan reaches it. The operating budget question is execution, so a bad answer is recoverable but almost never recovered, because nobody goes back and funds an operating model for a system already running. One tells you whether the program should exist. The other tells you whether it will still be worth anything in five years. Neither tells you about the liability floor, which is the mode most likely to kill a proposal that passes both.

One thing that should raise the cost of a bad result, and that this post has otherwise left implicit. A failed identity program does not simply waste its budget. It removes the option to try again for years, because the political capital to reopen the question does not regenerate on a delivery timetable. The United Kingdom is the worked example; the 2006 ID card scheme was abolished in 2010 after a limited rollout, that reversal removed the central-database option from Verify a decade later, and Verify's collapse in turn shaped what One Login was permitted to be in 2023. Two decades, three programs, each constrained by the wreckage of the last. So the diagnostic is about what the next program will be allowed to attempt, not only whether this one succeeds.

A note on reading a bad result. Execution modes are findings about delivery and funding, and they are inside your control. Five modes are structural and none of them

is reachable by a delivery plan. No anchor tenant, liability floor, political constraint, coordination failure, and locked-in architecture. A program in a structural mode has three honest options. Change the use case, change the rule, or stop. Continuing while calling it a delivery challenge is the specific mistake this record documents most often.

Some red flags show up in the documents themselves, and they are reliable. Generic statements about many potential use cases indicate no anchor tenant. Documents focused entirely on holder experience with no verifier analysis are describing half a system. Business cases with costs front-loaded and a thin operational tail are describing a slow failure. Vision statements about universal digital identity with no named first transaction are the strongest single predictor in the set.

## 20. Europe Is Running the Same Sequence Twice

Two of the three things in flight can be dealt with quickly, because this post has already given the reasons. Mobile driving licenses look healthy: TSA acceptance is a real anchor tenant under the section 12 test, and platform wallets solved distribution without asking anyone to install middleware. Their exposure is the temporal family, and it will arrive as uneven verifier implementations and a reader estate that ages the way the e-passport estate did. Passkeys are the outlier already discussed, succeeding at something identity programs cannot by handing the verifier a benefit on day one, while solving no part of the proofing problem.

eIDAS deserves the space, because it is not a new case. It is the same case, and the question is whether the sequence is being run twice.

The 1999 Electronic Signatures Directive created legal recognition for electronic signatures and a limited form of mutual recognition for qualified signatures. What it did not produce was workable cross-border interoperability. It established abstract legal and technical categories, set implementation in motion, and left many of the operational questions to be resolved later through standards work and national implementation. In practice national systems diverged, and a signature from one member state was not reliably accepted in another.

eIDAS, adopted in 2014 and applied from July 2016, made the cross-border framework explicit, and mandatory mutual recognition of notified national eIDs followed in September 2018. By then national markets, procurement choices and implementation patterns were well established. Europe ended up using a great many electronic signatures, mostly inside country-specific systems, which is what makes the outcome instructive; adoption was never the problem. The framework fell well short of the cross-border digital market its architects intended, not because too few people signed things, but because interoperability was specified after deployments had settled rather than before.

The ordering is decisive. Interoperability is a load-bearing choice, and retrofitting one is not a harder version of getting it right. Past a certain level of adoption it becomes a different and largely impossible project, because you are no longer designing a system. You are asking a set of working national systems to break themselves in favor of a market that does not exist yet, and nobody's budget contains that line.

The risk is that the sequencing repeats in the European Digital Identity Wallet rollout under the amended framework. This time there is considerably more deliberate work on common architecture, reference implementations, large-scale pilots, and conformance and interoperability testing, and it is the thing the first attempt most conspicuously lacked. Even so, member states are racing toward a fixed deployment deadline while technical specifications and conformance mechanisms are still evolving close to launch, and that combination produces a predictable incentive to optimize first for a functioning national system, defer the difficult cross-border problems.

Some countries will do that very well and stand up systems that work effectively within their borders. The difficulty arrives afterwards. Once those systems, contracts and user experiences harden, later harmonisation becomes expensive and politically awkward, some implementations may need substantial rework or replacement, and the incentive problem around who pays for interoperability and change reappears in the form it has had since 1999.

There is a second exposure that belongs to a different argument and bears on this one. Article 45's requirement that browsers recognize qualified website authentication certificates inverts the trust relationship the WebPKI depends on; admission becomes mandatory for the verifier while removal authority sits with the member state supervising the provider. I have written about that at length in the context of the classical WebPKI. The structural point is that when a framework compels acceptance rather than earning it, it has substituted a mandate for the verifier demand this whole post argues is the scarce input, and mandated acceptance works when the mandating party also carries the consequences, which is the condition Article 45 does not meet.

Japan closes the set, and section 12 has already told that story, of a mandate that moved the number and an operating model underneath it that ten per cent usage had been concealing. The detail worth carrying here is that not one item on the resulting list was a cryptographic or architectural failure. Every one was data quality and operations, surfaced all at once because acceptance had been compelled rather than earned.

So this generation offers three routes to acceptance that were not earned. A legislature compelling it under Article 45, platforms supplying it through wallet distribution, and Japan mandating it outright. The first has no accountability for consequences, the second has no accountability at all, and the third shows what the bill looks like when the mandate lands before the operating model does.



I hope the common testing and conformance work proves this concern wrong, and it is the part of the current effort most likely to. The honest test is whether, a few years after they ship, a citizen of one member state can use theirs in another without a special arrangement having been made for that corridor.

## 21. The Delegate That Cannot Be Handed a Piece of Paper

And then there is the thing none of this record was designed for. When I first wrote this analysis in 2025, AI was obviously significant and its relationship to identity was not obvious at all. It is becoming obvious now, and it arrives through the door the lifecycle argument was holding open.

Agents acting on a person's behalf are a delegation problem, and not metaphorically. An agent that files your tax return, disputes your benefit determination, books your appointment or negotiates on your behalf is exercising authority that belongs to you, within limits you set, revocably. That is a power of attorney with the paperwork replaced by a protocol. Everything said earlier about guardianship applies, with three differences that all cut the same way. The delegate is software rather than a person, so the authority must be machine-verifiable rather than presentable on request. The scope needs to be narrow and explicit rather than general, because nobody wants to grant an agent everything. And the volume is not a handful of instruments over a lifetime but potentially dozens of concurrent, short-lived grants.

Here is what that does to the argument in this post. For thirty years the acceptance side had no reason to want person-level identity strongly enough to pay for it, which is this post's subject. An agency dealing with a human on the telephone or at a counter has a workable if expensive answer; a person is standing there. An agency dealing with an agent has no such answer, and it needs one before it can process anything, because the first question is not who is this but was this actually sent by the person it claims to act for, and were they permitted to send it. That question cannot be answered from the agent's side. It has to be rooted in an identity the person holds.

Which makes agentic delegation the first plausible source of genuinely new verifier demand in the whole record. It passes the section 12 test cleanly; the motive is exogenous, it belongs to the verifier rather than to any identity program, and it exists whether or not anybody ships a wallet. A government that wants to let citizens' agents transact on their behalf, and every government will want that, because it is the cheapest queue reduction ever offered, cannot do it without a person-identity layer underneath. That is a demand signal thirty years of programs could not manufacture, arriving from a direction none of them was watching.

Before the cautions, the question a regulator will ask first, because the post has spent thirteen sections building the tools to see why it is hard. An agent acting for Alice instructs her bank, and the instruction is wrong. Perhaps it misread a document,

perhaps it invented a figure, perhaps a third party planted text in a web page the agent was reading and the agent did what the text said. Who is liable?

Agency law has an answer for human delegates and it does not transfer cleanly. A principal is bound by an agent acting within actual or apparent authority, which assumes the agent is a person or the instrument of one, that scope is legible to the counterparty, and that the agent is not itself steerable by strangers. Prompt injection breaks the third assumption in a way agency doctrine has never had to contemplate; apparent authority becomes something an unrelated party can manufacture by publishing the right text where the agent will read it. And the bank cannot hand its own obligation to anybody, so it ends up holding its non-delegable duty, plus a new question about whether the instruction was authorized, plus no ability to inspect how the agent reached it.

Which turns the scoping question from a privacy nicety into the containment mechanism. A grant that is narrow, time-limited, machine-verifiable and revocable exists so that when the agent is wrong, and it will be, the blast radius is bounded to something the verifier can price and the principal can survive. Design the binding for general delegation and you have built an instrument nobody can safely accept.

Two cautions, because this is the part of the post most likely to age badly. The first is that a new source of demand does not repeal anything else here, and the liability floor still applies. The second is lock-in. If a binding model cannot represent a guardian acting for one person, it certainly cannot represent forty scoped, time-limited, revocable grants to software. The programs now being designed will be the substrate for this whether or not they were built for it, and the binding decision is being made right now, at the whiteboard, by people optimizing for launch.

#### KEY LESSON

For thirty years the acceptance side had no reason to want person-level identity badly enough to pay for it. An agency dealing with a human at a counter can see a person standing there. An agency dealing with that person's agent cannot, and needs an answer before it can process anything. That is the first demand signal in this record that nobody had to manufacture.

## 22. What the Record Is Actually Telling Us

Set out plainly, the chain runs like this. Issuance is what the issuer controls, so it is what gets funded and scored. Acceptance is what decides whether the system exists, and it sits with parties the issuer can neither compel nor pay. So programs optimize the half they own and the deciding half goes unbudgeted, which is the largest family in the record. Where the deciding half did get solved, it was solved by a verifier who arrived with an independent reason to verify, or, in the Nordic and defense cases, because the verifier and the builder were the same institution and no persuasion was needed. Where the verifier wants to accept and cannot, the obstacle is a liability rule rather than a protocol, which determines not how well an architecture works but whether it is available at all. Then the same asymmetry runs forward in time, because

launch is scored and operation is not, and that is slow failure, with lock-in ensuring that by the time the consequences are legible, the choices producing them can no longer be revised.

That chain is the contribution. Not the observation that identity is a governance problem, which has been said for twenty years and has not changed anybody's program plan.

What follows is less comfortable than the usual conclusion. The standard closing move is that this generation can learn from history if architects and policymakers internalise the lessons. But the lessons have been available the whole time. Verify's designers had the 1999 Directive and the nPA in front of them. One Login's designers had Verify. The failure is not of knowledge, and exhorting people to learn is unlikely to work on the twenty-ninth attempt when it did not work on the first twenty-eight.

The structural reading suggests something narrower and more actionable. Change what gets measured. A program reported on credentials issued will optimize credentials issued, because that is what people do. A program reported on transactions completed at a verifier who was under no obligation to participate has to solve the deciding half, because there is no other way to make the number move. The metric is the only lever in this post that reaches the asymmetry rather than describing it.

The record does not establish it. Nothing here demonstrates that a program which switched to verifier-side outcome metrics performed differently, because I could not find one that switched. A program measured on completed transactions at an unobliged verifier is a different object from any program in this record, which is the argument for doing it and equally why nobody can point to the evidence. Reasoned, not demonstrated, and the cheapest thing anybody could do to test the thesis is to run it once and publish what happened.

With one addition, because a metric composed only of successes has a blind spot exactly where this post has spent its time. Report the failures alongside. The proportion of attempts that do not complete, the populations that cannot complete them at all, the fraud that got through, the verifiers that looked and declined. Verify's verification success rate was knowable throughout and was not the number anyone was managing to. And the people in section 9, the older holder whose fingerprint will not read, the guardian with no lawful way to act, are invisible by construction in any measure of completed transactions, because somebody who cannot start does not appear in a count of those who finished. If exclusion is not on the report, it is not a finding anyone will ever have to answer for.

*Thirty years of this record suggests the field does not have a knowledge problem. It has an accountability problem, and the accountability sits on the wrong half of the system.*

The opening of this post listed five claims. Here is what the record did to them, which is not quite the same list.

The cryptographic point survived, with its scope now stated: in this sample I did not identify weak cryptography as the primary cause of any failed outcome. The anchor tenant claim survived but narrowed into something more demanding than a best practice, because the test is not size or enthusiasm but whether the verifier's motive predates your program, and the highest-adoption systems in the record went one better by having the verifier build the thing itself. The liability floor survived and sharpened into a ceiling; residual responsibility caps what any credential can remove, and the response to a proposal that needs the ceiling raised is to name the statute it intends to change.

Two changed under examination. The claim that acceptance decides turned out to be true in a more uncomfortable way than stated, because sorting the record by category shows that programs able to compel acceptance do clear the hurdle, and then pay for it in political exposure and in an operating bill nobody costed. The demand problem is not solved by mandate, it is deferred and repriced, which is what Japan bought with a health-insurance card and what Article 45 is buying now. And the governance claim acquired a price: One Login shows what a single unfunded standing function costs when it fails, which is nine months off the register because a supplier let its own certificate lapse.

One claim was added rather than tested, and it should be marked as such. Nothing in this record establishes that agentic delegation will create the demand I have argued it might, because the record ends before the question is settled. It is the one forward-looking bet in the post, it is falsifiable within a few years, and if it is wrong the rest of the argument is unaffected.

What remains is the measurement argument, and it is the only lever here that reaches the asymmetry rather than describing it. Which makes the closing question about any working identity system not whether it works, but who is answerable for its still working in five years, and where the acceptance problem looks solved at consumer scale, who solved it, because for this generation the answer is three companies that were never asked to take the job.

## What this post does not establish

The record is drawn from wealthy countries and national-scale programs. Brazil, Nigeria, Indonesia and China are absent. That bounds the central claim: "acceptance decides" assumes a verifier who can decline, and where the state is at once issuer, dominant verifier and beneficiary, it does not hold in the same form. Aadhaar is the only entry approaching that shape.

Two disclosures. I am an author of the GIDS specification and I contributed to PIV, and both are in the record; GIDS is tagged as a failure, and I have an obvious interest in that failure being about demand rather than about design. Utah's SEDI work is in the record as a program I advise on and have spoken in support of, and this analysis started as a talk at their summit. It is tagged in flight with the two modes the instrument indicates, which is checkable against the table, and nothing here is evidence that it works because there is not yet anything to be evidence of.

Where this post gives a number it has been checked against a source. Where it explains why something failed, that is my reading of the case.

These figures are not verified against a primary source: Estonia's 120,000 faulty cards in 2011 and roughly 760,000 affected in 2017; the \$647 million of Washington state unemployment fraud; the claim that certificate checking was relaxed as a workaround in e-passport deployments, which is the load-bearing half of that argument; the 7,312 mismatched Japanese insurance records, for which I have contemporaneous reporting but not the ministry's own release; itsme's adoption figures, which are company-published; the Scandinavian and Singapore adoption and benefit numbers; and the Cabinet Office accounting officer assessment of 2022, which I have not resolved to a permanent URL. The ten-to-one cost ratio between hardware tokens and SMS delivery in section 16 is an order of magnitude from practice rather than a sourced figure. The comparison between the Apple and Android security models in the same section, the SD-JWT linkability and server-retrieval claims in section 7, and the characterisation of Italian policy direction in section 20 are my own reading rather than anything cited.

## Sources

## Appendix A — The Record

32 programs, 1999 to 2024. Solid entries are primary causes; entries marked contributing are secondary. Of the 28 where an outcome could be identified, 19 worked. In this sample, weak cryptography was not identified as the primary cause of any failed outcome.

| Program                                       | Where               | From | Failure modes                                                                                 | What happened                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|-----------------------------------------------|---------------------|------|-----------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Digital Signature Directive 1999/93/EC</b> | European Union      | 1999 | Failed · No anchor tenant; Framework without enforcement; Coordination failure (contributing) | Legal recognition for e-signatures, and a limited mutual recognition for qualified ones, without the operational interoperability that would make either useful across a border. Categories set, implementation started, the hard questions left to standards work and national discretion. Diverged accordingly.                                                                                                                                                                                                                                                                                                               |
| <b>Federal Bridge / FPKI</b>                  | United States       | 2000 | Working · Verifier integration cost (contributing)                                            | Routinely cited as the PKI era's emblematic failure, which the record does not support. Its stated scope was interoperability between federal agency PKIs and the entity domains that transact with them, and within that scope it worked: commercial bridges cross-certified because their members needed to do business with agencies requiring the credentials, CertiPath for aerospace and defense supply chains and SAFE-BioPharma for pharmaceutical exchange with FDA and DoD. Cross-certification is expensive, and it never reached commercial-to-commercial use where no agency was a party. That was never the goal. |
| <b>CAC</b>                                    | United States (DoD) | 2000 | Working                                                                                       | Four million-plus personnel. Bounded scope, certain enforcement, and the beneficiary paying. Generalised no further, and was never meant to.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| <b>Estonia eID</b>                            | Estonia             | 2002 | Working · Governance underfunded (contributing)                                               | The sequencing exemplar: embedded in tax, voting, prescriptions and business registration from day one, and it worked for that reason. What it did not do was model failure of the credential itself at population scale. Roughly 120,000 faulty cards in 2011, then a 2017 chip vulnerability affecting about 760,000 and a national freeze. The response was competent and it was improvised, because mass revocation and recovery had not been designed as a normal operating condition.                                                                                                                                     |
| <b>Liberty Alliance / SAML</b>                | Industry consortium | 2002 | Failed · Verifier integration cost; Coordination failure (contributing)                       | Survives in enterprise federation. Never reached the consumer web it was aimed at, because the integration cost only made sense where an IT department was already paying it.                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>Sweden BankID</b>                          | Sweden              | 2003 | Working                                                                                       | Bank-led, resting on identity obligations and fraud exposure the banks already carried. Institutional trust reused rather than manufactured.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| <b>Singpass</b>                               | Singapore           | 2003 | Working                                                                                       | Government-led with genuine utility from the outset, then iterated continuously, including rapid pandemic adaptation. The funded operating model is the differentiator.                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| <b>PIV (HSPD-12)</b>                          | United States       | 2004 | Working · Verifier integration cost (contributing)                                            | Worked inside the mandate for the same reasons as CAC. Adoption outside the federal population never happened; the integration burden had no corresponding payoff.                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <b>Norway BankID</b>                          | Norway              | 2004 | Working                                                                                       | Same mechanism as Sweden. The verifier                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |

| Program                              | Where          | From | Failure modes                                                                                                                               | What happened                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|--------------------------------------|----------------|------|---------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                      |                |      |                                                                                                                                             | arrived with its own motive and funded the system it wanted.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| <b>DigiD</b>                         | Netherlands    | 2005 | Working                                                                                                                                     | Government login for public services, run by the state and accepted across it. The verifier and the issuer are the same institution, so no persuasion across a boundary was needed.                                                                                                                                                                                                                                                                                                                                                                         |
| <b>iDIN</b>                          | Netherlands    | 2016 | Working                                                                                                                                     | Bank-backed identity for private-sector use, built by the parties already carrying know-your-customer obligations. Offered alongside DigiD in a government pilot as an alternative a user could choose, not integrated into it. Acquired by itsme in December 2025.                                                                                                                                                                                                                                                                                         |
| <b>E-passports (ICAO Doc 9303)</b>   | 150+ countries | 2005 | Working · Governance underfunded; Framework without enforcement; Locked-in architecture (contributing); Coordination failure (contributing) | The most widely deployed identity credential in history, and the clearest case of a sequence run backwards. Chips went to hundreds of millions of people before the directory participation, validation infrastructure and reader estates that made them worth checking existed, and the early workaround was to relax certificate checking. The interoperability did arrive, roughly two decades later, which is the finding rather than the exoneration: the system spent twenty years below its promise and no year of that appeared on anyone's report. |
| <b>UK National ID Cards scheme</b>   | United Kingdom | 2006 | Failed · Political constraint; No anchor tenant (contributing)                                                                              | The Identity Cards Act created a card and a national register in 2006, and a limited rollout issued cards before the coalition government abolished both in 2010. The political reversal, not a technical one, took a central register off the table for everything that followed, which is the constraint Verify was designed around.                                                                                                                                                                                                                      |
| <b>InfoCard / CardSpace</b>          | Microsoft      | 2006 | Failed · Verifier integration cost; No anchor tenant; Holder friction (contributing)                                                        | Architecturally correct and still is. Windows-dependent, complex to integrate, and overtaken by a protocol that asked developers for far less and gave verifiers more.                                                                                                                                                                                                                                                                                                                                                                                      |
| <b>OAuth and OpenID Connect</b>      | Industry       | 2007 | Working · Framework without enforcement (contributing); Locked-in architecture (contributing)                                               | Won on integration cost by handing verifiers something they already wanted. Fragmented in practice, with dominant implementations becoming the de facto specification.                                                                                                                                                                                                                                                                                                                                                                                      |
| <b>nPA national ID card</b>          | Germany        | 2010 | Failed · Cost/benefit misaligned; Holder friction; Verifier integration cost (contributing); No anchor tenant (contributing)                | Sound cryptography, and the record's cleanest natural experiment. Automatic activation from 2017 took the issuance number past 97 per cent of cards in circulation; actual use went from just under ten per cent in 2022 to 22 per cent in 2024. The issuer controlled one number and not the other.                                                                                                                                                                                                                                                        |
| <b>Aadhaar</b>                       | India          | 2010 | Working · Political constraint (contributing); Exclusion (contributing); Governance underfunded (contributing)                              | The largest deployment ever attempted, with real effect on benefit delivery and financial inclusion. Purpose limitation, exclusion and oversight remained unresolved until the courts intervened in 2018.                                                                                                                                                                                                                                                                                                                                                   |
| <b>GIDS smart card specification</b> | Microsoft      | 2010 | Failed · No anchor tenant                                                                                                                   | The counterexample to the distribution argument, and the reason it needs qualifying. A class minidriver shipped in box with every Windows since 7 SP1, so a GIDS card works with no middleware at all, and it was designed for remote deployment, meaning credentials provisioned to a device rather than issued across a counter. It still went essentially                                                                                                                                                                                                |



| Program                             | Where          | From | Failure modes                                                                                                                                                                                          | What happened                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|-------------------------------------|----------------|------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                     |                |      |                                                                                                                                                                                                        | nowhere outside Microsoft's own stack, where it backed Windows virtual smart cards. Distribution was solved. No verifier outside that stack ever needed a GIDS card.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>NSTIC</b>                        | United States  | 2011 | Failed · No anchor tenant; Coordination failure; Cost/benefit misaligned (contributing)                                                                                                                | Funded pilots, convened participants and waited for a market to form, which is enabling an ecosystem rather than building one. No large service required the credentials, so no provider had a reason to invest, and the chicken-and-egg problem was never broken.                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <b>My Number</b>                    | Japan          | 2015 | Working · Governance underfunded; Coordination failure (contributing); Political constraint (contributing)                                                                                             | The mirror image of the nPA. Japan moved the issuance number with cash incentives and by folding the health insurance card into it, rather than by changing a default. Forcing acceptance then surfaced what low usage had concealed: 7,312 cases of insurance records linked to the wrong individual, wrong residence certificates printed at convenience stores, a nationwide record-by-record recheck devolved to municipalities, and the insurance card phase-out delayed a year.                                                                                                                                                                                                                  |
| <b>GOV.UK Verify</b>                | United Kingdom | 2016 | Failed · Political constraint; Coordination failure; No anchor tenant; Holder friction; Exclusion (contributing); Framework without enforcement (contributing); Cost/benefit misaligned (contributing) | Seven modes, in causal order. A political constraint (no central database) forced a federated design; federation across commercial providers created a coordination problem; differing evidence rules made the holder experience unpredictable, producing a 48% single-attempt verification success rate (a measure the NAO cautioned excluded people who abandoned before provider confirmation) and demographic exclusion; certification was to a standard rather than to a working transaction; providers were paid per verification at volumes that never arrived; and departments had alternatives with no mandate to switch. 19 of a forecast 46, 48% verification success against 90% expected. |
| <b>SPID, and the CIE succession</b> | Italy          | 2016 | Working · Locked-in architecture (contributing); Political constraint (contributing)                                                                                                                   | SPID reached critical mass through pandemic-era mandates, and a state-controlled alternative in CIE has existed alongside it throughout. The interest here is structural rather than current-affairs: whichever way the policy lands, tens of millions of holders and a relying-party estate already depend on the federated architecture, which makes this the one case in the record where lock-in can be watched rather than reconstructed.                                                                                                                                                                                                                                                         |
| <b>itsme</b>                        | Belgium        | 2017 | Working                                                                                                                                                                                                | A bank and telco consortium, built by the parties already carrying AML, PSD2 and SIM-registration obligations. Around 7.5 million users and over 80 per cent of Belgian adults, with more than a million actions a day, and no government mandate anywhere in the story: it grew because it was the quickest way into banking. The institutional-trust pattern outside Scandinavia, which is the case that makes the cultural explanation hard to sustain. Acquired iDIN in December 2025 and is expanding across the EU ahead of EUDI.                                                                                                                                                                |
| <b>Login.gov</b>                    | United States  | 2017 | Working · Exclusion (contributing)                                                                                                                                                                     | Deliberately unambitious scope, usability chosen over architecture. Works modestly where the grand designs did not.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |

| Program                                    | Where                                  | From | Failure modes                                                                                               | What happened                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|--------------------------------------------|----------------------------------------|------|-------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>FIDO2 / passkeys</b>                    | Industry + platforms                   | 2018 | Working                                                                                                     | Not identity proofing, and succeeding anyway. Driven by an immediate relying-party benefit of no password database and fewer recovery tickets, plus platform distribution, with no mandate anywhere.                                                                                                                                                                                                                                                                                                                                                                                |
| <b>Bank KYC via verifiable credentials</b> | Multiple                               | 2019 | Failed · Liability floor; Verifier integration cost (contributing)                                          | A recurring proposal meeting a recurring wall. A regulated firm may use a certified verification service for parts of customer due diligence, but it remains responsible for the adequacy of the overall determination, so the credential removes less duplicated work than the pitch assumes.                                                                                                                                                                                                                                                                                      |
| <b>MOSIP deployments</b>                   | Philippines, Ethiopia, Morocco, others | 2020 | In flight · Exclusion (contributing); Governance underfunded (contributing)                                 | Open-source foundational identity for states without the capacity to build their own, aimed squarely at the exclusion problem. The standing risk is a platform adopted faster than the governance capacity to operate it.                                                                                                                                                                                                                                                                                                                                                           |
| <b>mDL / ISO 18013-5 + TSA</b>             | United States                          | 2021 | Working · Framework without enforcement (contributing); Governance underfunded (contributing)               | TSA acceptance is the clearest anchor tenant in the modern record, an obligation predating the credential and made cheaper by it. Verifier implementations and reader estates are the exposure.                                                                                                                                                                                                                                                                                                                                                                                     |
| <b>Entra Verified ID</b>                   | Microsoft                              | 2022 | Uncertain · No anchor tenant; Verifier integration cost (contributing); Coordination failure (contributing) | An active product with continuing investment and several first-party uses, including generally available account recovery from 2026, but without public adoption data sufficient to compare it with Microsoft's established federation products, and wallet interoperability has not visibly materialised at scale. Outcome not classifiable from the public record.                                                                                                                                                                                                                |
| <b>GOV.UK One Login</b>                    | United Kingdom                         | 2023 | Working · Governance underfunded; Exclusion (contributing); Political constraint (contributing)             | Built to learn from Verify, and exposed to a different failure. Removed from the DIATF register for roughly nine months in 2025 after a supplier allowed its own certification to lapse, with no finding against One Login's own security or approach. The service kept operating and expanding throughout, past 200 services and 15 million proven identities. A supplier-governance failure inside a working program rather than a failed one.                                                                                                                                    |
| <b>Utah mobile identity (SB260)</b>        | Utah                                   | 2023 | In flight · No anchor tenant (contributing); Coordination failure (contributing)                            | State-endorsed rather than state-controlled, with KERI-based rotation and recovery, offline verifiability, and delegation and guardianship treated as design requirements rather than later remediation. Its exposure is the one this record punishes most: no verifier has yet been named whose need to check identity predates the program, and a multi-state consortium is the shape section 13 describes as many independent parties needing to converge with nothing obliging them to. KERI is also a young stack to bet a statutory framework on. No outcome to classify yet. |
| <b>eIDAS 2.0 / EUDI Wallet</b>             | European Union                         | 2024 | In flight                                                                                                   | Real technical unification across ISO 18013-5, W3C verifiable credentials, SD-JWT and mdoc, plus a mutual recognition obligation with legal force. Also a framework permitting variable national implementation. Exposed to framework-without-enforcement, coordination failure and the liability floor. No outcome to classify yet.                                                                                                                                                                                                                                                |

## Appendix B — Reading a Proposal

Twenty questions mapped to the eleven failure modes. Every answer that describes the weaker case is a mode the proposal is exposed to. Five of the eleven are structural and no delivery plan reaches them.

### 1. Can you name the anchor tenant?

A specific verifier, named, whose participation is committed rather than hoped for.

### 2. Would that verifier still need to solve this problem if your program did not exist?

A motive your program created disappears when your funding does.

### 3. If a mandate is part of the plan, what exactly is being mandated?

Compelling a transaction people need works. Compelling possession of a credential moves the issuance number and not the acceptance one.

### 4. What will acceptance cost the verifier, and who pays it?

Integration, training, support, and the ongoing cost of accepting.

### 5. Who remains liable when a credential turns out to be wrong?

If the verifier does, and regulation says it must, the credential cannot reduce its risk.

### 6. If liability is meant to transfer, who absorbs the loss and what are they paid?

A transfer capped below the harm, on per-verification fees, has not moved the risk. It has moved the paperwork.

### 7. Is an institutional override, meaning revoke or freeze or suspend, legally required here?

Court orders, sanctions, safeguarding. Holder-controlled architectures limit this by design.

### 8. Who pays for the credential, and who benefits from it?

Systems where the holder pays and the verifier benefits stall.

### 9. What must the holder obtain, install or visit before first use?

The nPA asked for an office visit, middleware and a purchased reader. Passkeys ask for nothing.

### 10. Which populations cannot complete enrolment as designed?

Evidence and device assumptions, degraded biometrics in older users, children, and anyone acting under a power of attorney or guardianship.

### 11. Is assurance set per transaction, or once for the whole system?

A single IAL/AAL posture across every use is not a risk decision, it is eleven decisions avoided.

### 12. Which architectural choices were made for political acceptability rather than function?

Verify's federated design existed to avoid a central database. That choice created its coordination problem.

### 13. If this is a new standard, what stops being used, and what makes it stop?

A mandate with consequences, a buyer too large to refuse, or default platform distribution. Not that yours is better.

### 14. If two implementations disagree, who decides and who is bound?

Conformance testing, certification, and a consequence for failing it.

### 15. How many independent parties must converge for this to work?

And what forces them to, absent a mandate or an anchor tenant?

### 16. Who was in the room before the design was fixed?

Volume, habit and breadth. One department specifying alone will encode that department, and every other will find the fit wrong.

### 17. What is the annual operating budget, as a share of build cost?

Security review, supplier verification, protocol migration, conformance testing.

### 18. Which security properties are load-bearing by accident?

Mechanisms borrowed for a property they were not designed to provide, where the party being relied on never agreed to it. SMS one-time passwords are the standing example.

**19. Which of today's choices will be unfixable at scale?**

Identifier format, revocation model, algorithm agility, trust-anchor update.

**20. What is the primary success metric?**

Credentials issued measures the half you control. Completed transactions measures the half that decides.

# Sources

1. European Parliament and Council, Directive 1999/93/EC on a Community framework for electronic signatures, 13 December 1999.
2. Estonian Information System Authority and the national ID service, on the 2017 ROCA-related eID vulnerability and the certificate suspension affecting cards issued from October 2014, and on the 2011 faulty card distribution.
3. Federal PKI Policy Authority and cross-certified bridge documentation: the FBCA certificate policy scope, established to facilitate interoperability between the FBCA and other entity PKI domains; the FPKIMA newsletter on the CertiPath bridge serving the defense and aerospace community and the SAFE-BioPharma bridge serving healthcare; and CertiPath's PIV-I cross-certification, taken up so that supply-chain members could do business with federal agencies requiring medium to high assurance credentials.
4. Danish government digital signature study of 1999, from which NemID grew, and the state-funded rather than market-competed basis of the scheme; see the MitID and NemID histories and the Danish Agency for Digitalisation.
5. Danish law requiring digital communication with the public sector from November 2014, and the practical dependency on NemID to access it, described by IT-Politisk Forening, including the exemption process and the recommendation that citizens unable to comply authorise a family member.
6. Social Security Administration, history FAQ: cards issued from 1946 carried the legend “FOR SOCIAL SECURITY PURPOSES, NOT FOR IDENTIFICATION”, and the legend was removed with the eighteenth design version issued from 1972. On the first numbers being issued in November 1936, see the SSA's account of the first card.
7. NIST, Report of the Federal Bridge Certification Authority Initiative and Demonstration, October 2000, for the FBCA prototype going operational on 8 February 2000 and the five interoperating domains demonstrated that April.
8. ICAO, Doc 9303, Machine Readable Travel Documents, and the ICAO Public Key Directory, for the specification and the participation record behind it.
9. Regulation (EU) 2024/1183 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework, eIDAS 2.0, including Article 45 on qualified website authentication certificates.
10. National Audit Office, Investigation into Verify, March 2019 (full report, PDF). Every figure cited here was checked against that document: 19 connected services, 48 per cent verification success, 3.6 million sign-ups against a 25 million target, at least £154 million of cost to September 2018, the £873 million to £217 million benefits revision, £37 million a year of claimed avoided building costs, the non-cash-releasing classification, the finding that the NAO could not replicate or validate the estimated benefits, and HMRC's £6.7 million as the only departmental payment. Cabinet Office Accounting Officer Assessment, 20 September 2022, for £485.3 million of benefits against £233.38 million of cost through 2021/22 and the 2.1:1 ratio.
11. On GOV.UK One Login: Computer Weekly for the DIATF lapse via supplier iProov and automatic removal from the register; Biometric Update for iProov's recertification dated 16 October 2025; PublicTechnology for the return to the register and the supply-chain tracking that followed; Biometric Update for the £18m in Accenture and PA Consulting contracts, a ceiling rather than a recorded spend.
12. Personalausweisportal (German Federal Ministry of the Interior), on offering electronic identification: automatic eID activation on collection since July 2017, and roughly 70.4 million activated cards by October 2024, over 97 per cent of those in circulation.
13. Supreme Court of India, Justice K. S. Puttaswamy (Retd.) v. Union of India, 26 September 2018, on limits to mandatory Aadhaar use.
14. Washington State Employment Security Department, newsroom, on pandemic-era unemployment insurance fraud losses and recoveries.
15. NIST, post-quantum cryptographic standards, August 2024: FIPS 203, FIPS 204 and FIPS 205.
16. NIST, Special Publication 800-63, Digital Identity Guidelines, and its component volumes on enrollment and identity proofing, authentication and lifecycle management, and federation and assertions. The earlier 800-63-3 remains the most widely cited revision.
17. United Nations Legal Identity Agenda, and the MOSIP foundational identity platform, for the digital public infrastructure framing and deployment status across the Philippines, Ethiopia, Morocco and other adopters.
18. Initiative D21 and the Technical University of Munich, eGovernment MONITOR, 2022 and 2024 editions, for online-ID usage of 10 per cent in 2022, 14 per cent in 2023 and 22 per cent by May 2024, alongside 39 per cent having set a PIN.
19. Michael E. Rose, Jörg Hoffmann and Dietmar Harhoff, “Wer hat die elektronische Ausweisfunktion aktiviert?”, Wirtschaftsdienst 105 (7), 2025, 525–528 (doi:10.2478/wd-2025-0134). Max Planck Institute for Innovation and Competition. Survey conducted October 2024: 35 per cent of the adult resident population had activated the eID and 6 per cent did not know it existed, Berlin highest at 53.6 per cent.

20. Sumsub, identity fraud reporting, on deepfakes as a share of detected identity-fraud attempts. Vendor-published, with a commercial interest in the number being large. The post does not rely on the figures and says why.

21. US Government Accountability Office, Unemployment Insurance: Estimated Amount of Fraud during Pandemic Likely Between \$100 Billion and \$135 Billion, GAO-23-106696, September 2023 (PDF). Covers April 2020 to May 2023, or about 11 to 15 per cent of total benefits paid.

22. Japanese Ministry of Health, Labour and Welfare disclosure of May 2023 on My Number health-insurance record linkage, for 7,312 records linked to the wrong individual between October 2021 and November 2022; plus contemporaneous reporting on the convenience-store certificate misprints, the June 2023 emergency review, the national record-by-record recheck, and the year's delay to the insurance-card transition. The ministry's standing policy hub is at [mhlw.go.jp](https://mhlw.go.jp) and covers the program but not this disclosure.

23. itsme / Belgian Mobile ID, published user numbers, and Biometric Update on the December 2025 acquisition of iDIN. Adoption figures are company-published.

24. Microsoft, Windows inbox smart card minidriver, for the class minidriver supporting PIV and GIDS card edges shipped from Windows 7 SP1 onward, and the PIV-then-GIDS discovery order.

25. Microsoft, announcement of the Credentica acquisition, March 2008, stating the intention to bring U-Prove into Windows Communication Foundation and Windows CardSpace, and Kim Cameron's contemporaneous commentary. CardSpace shipped in 2006 and was discontinued in 2011.

26. Ross Anderson, Security Engineering: A Guide to Building Dependable Distributed Systems, for the NSA definitions adopted throughout: a trusted system or component is one whose failure can break the security policy, and a trustworthy one is one that will not fail.

27. Utah State-Endorsed Digital Identity and the Department of Government Operations paper Protecting Liberty. The delegation and guardianship distinction is Timothy Ruff's formulation from the October 2025 SEDI Summit at Utah Valley University, reported by TechBuzz News: delegation temporarily assigns duties without transferring legal responsibility, guardianship legally transfers authority and responsibility.

28. Randall Munroe, "Standards", xkcd 927. The comic is not reproduced here; the upper row of the figure in section 17 restates its argument as a sequence diagram in order to contrast it with the case where a forcing function exists. xkcd is published under a Creative Commons Attribution-NonCommercial 2.5 license.

29. Regulation (EU) No 910/2014 of 23 July 2014 on electronic identification and trust services, repealing Directive 1999/93/EC, applying from 1 July 2016, with mutual recognition of notified electronic identification schemes mandatory from 28 September 2018.